



Institute of Network Experts

AWS Cloud Incident Response

Vivek Maurya

Acknowledgement

I would like to thank the people who supported this project and helped me understand cloud security and incident response. The exercise gave me an opportunity to work with AWS services such as IAM, CloudTrail, CloudWatch and S3 and to practice looking at cloud activity from an incident responder point of view.

The project was especially useful because it connected security concepts with real console evidence. Instead of only reading about an incident, the investigation required reviewing events, checking permissions, comparing timestamps and understanding what each action meant.

Abstract

This project studies a simulated AWS cloud compromise. During the exercise, two IAM users - kiki and viki1234 - were created without MFA. The user kiki received the AdministratorAccess policy, while viki1234 received ReadOnlyAccess. Later activity showed reconnaissance of IAM, S3 and CloudTrail, access to test data and attempts to weaken logging by using StopLogging and DeleteTrail events. Some attempts were denied, but at least one DeleteTrail and one StopLogging action succeeded.

The investigation was performed from the AWS Management Console using CloudTrail Event History, CloudWatch Logs Insights, IAM and S3. The evidence was then organized into a timeline, root cause analysis, impact assessment and remediation plan. The main lesson is that cloud security depends on strong identity controls, protected logging and fast detection of unusual administrative actions.

Table of Contents

1. Executive Summary
2. Introduction and Objectives
3. Environment Setup
4. Logging Configuration
5. S3 and IAM Configuration
6. Incident Simulation Narrative
7. Investigation Methodology
8. Evidence and Timeline Analysis
9. Root Cause Analysis
10. Impact Assessment
11. Indicators of Compromise
12. Remediation Recommendations
13. Detection and Monitoring Improvements
14. Lessons Learned
15. Conclusion

List of Figures and Evidence Images

- Figure 1. AWS console and sandbox environment
- Figure 2. CloudTrail creation and logging settings
- Figure 3. CloudTrail trail details
- Figure 4. S3 log and data buckets
- Figure 5. IAM user kiki and viki1234
- Figure 6. Initial foothold and privilege escalation
- Figure 7. Secondary foothold and reconnaissance
- Figure 8. Suspicious S3 activity
- Figure 9. CloudTrail anti-forensics activity
- Figure 10. CloudTrail event history filtering
- Figure 11. Detailed event lookup
- Figure 12. CloudWatch Logs Insights evidence
- Figure 13. Root cause evidence
- Figure 14. Impact evidence
- Figure 15. IOC evidence
- Figure 16. Remediation evidence

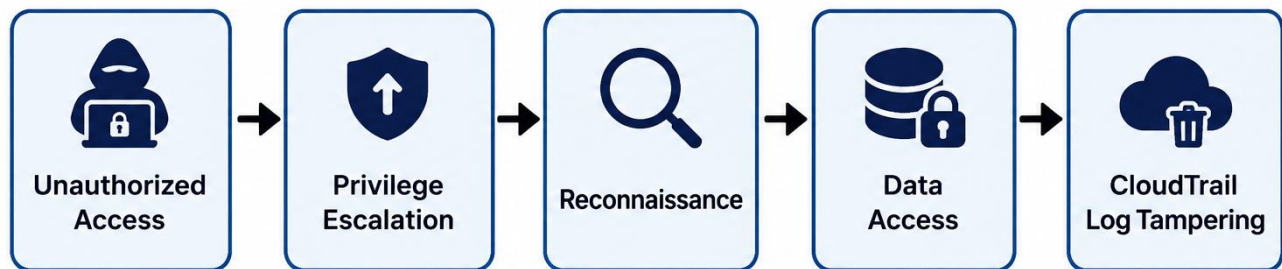
1. Executive Summary

The investigation found suspicious activity inside the AWS sandbox. Two IAM users were created: kiki and viki1234. Neither account had MFA enabled. The account kiki was given AdministratorAccess, which gave it broad control over the environment. The second user, viki1234, was used for reconnaissance against IAM, S3 and CloudTrail.

The activity later moved from discovery to data access and logging tampering. A credentials file and salary data were present in the S3 data bucket. CloudTrail events showed attempts to stop logging and delete a trail. One StopLogging attempt was denied, but later DeleteTrail and StopLogging activity succeeded, creating a visibility problem for the investigation.

The key security lesson is simple: a cloud account can become high-risk very quickly when identity controls are weak. An unauthorized user with broad permissions can create more access, inspect the environment, reach sensitive storage and try to reduce the evidence available to defenders.

Attack Flow



The sequence is based on the events recorded in the supplied AWS sandbox report.

Figure 1. High-level flow of the simulated compromise

2. Introduction and Objectives

2.1 Purpose of the Exercise

The project was designed to simulate a realistic cloud compromise in an AWS sandbox and to practice the work of an incident responder. The main task was not only to find suspicious events, but also to put those events in the correct order and explain what each event meant.

2.2 Scope

- Environment: AWS sandbox account in Asia Pacific (Mumbai).
- Primary console tools: CloudTrail, CloudWatch Logs Insights, IAM, S3 and Athena as listed in the original project.
- Investigation constraint: console-based work only, without AWS CLI or scripts.
- Objective: reconstruct the attacker story, assess impact and recommend remediation.

2.3 Main Questions

- How were the suspicious identities created?
- When did privilege increase?
- Which resources were explored?
- Which data was accessed?
- Did the attacker try to hide activity?
- What evidence remained after the logging disruption?

3. Environment Setup

The investigation was performed in an AWS sandbox located in the Asia Pacific (Mumbai) region. The original report records the account as a sandbox account under vikas maurya. The AWS Management Console was used as the main working interface.

3.1 Relevant Services

- IAM was used to create users and review their permissions.
- S3 was used for the log bucket and the test data bucket.
- CloudTrail recorded management events and was the main source for the investigation timeline.
- CloudWatch Logs Insights was used to search the delivered log data.

The important point is that these services are connected from an incident response perspective. IAM tells us who can act, CloudTrail tells us what action occurred, S3 shows where data was stored, and CloudWatch provides another place to query the events.

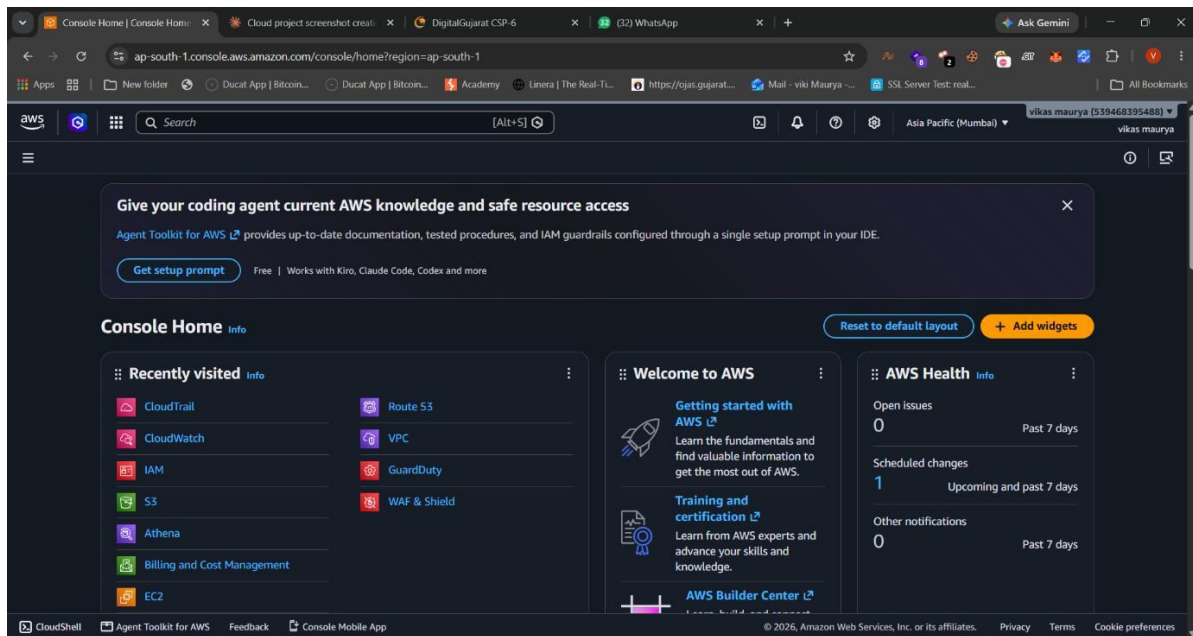


Figure 2. AWS console showing the sandbox environment and Mumbai region

4. Logging Configuration

A CloudTrail trail named office-cloud-trail was created for the exercise. Multi-region logging was enabled and the logs were delivered to the S3 bucket officelogs. The project also records KMS encryption with the alias kmss and CloudWatch integration with the log group office-watch-log.

4.1 Why this configuration mattered

CloudTrail was the main evidence source. Because the investigation depended on timestamps and event names, the trail was important for building the incident story. CloudWatch provided a second way to search the delivered events. The existence of an S3 log destination was also useful because cloud logs should ideally be stored in a location where they are protected from ordinary user changes.

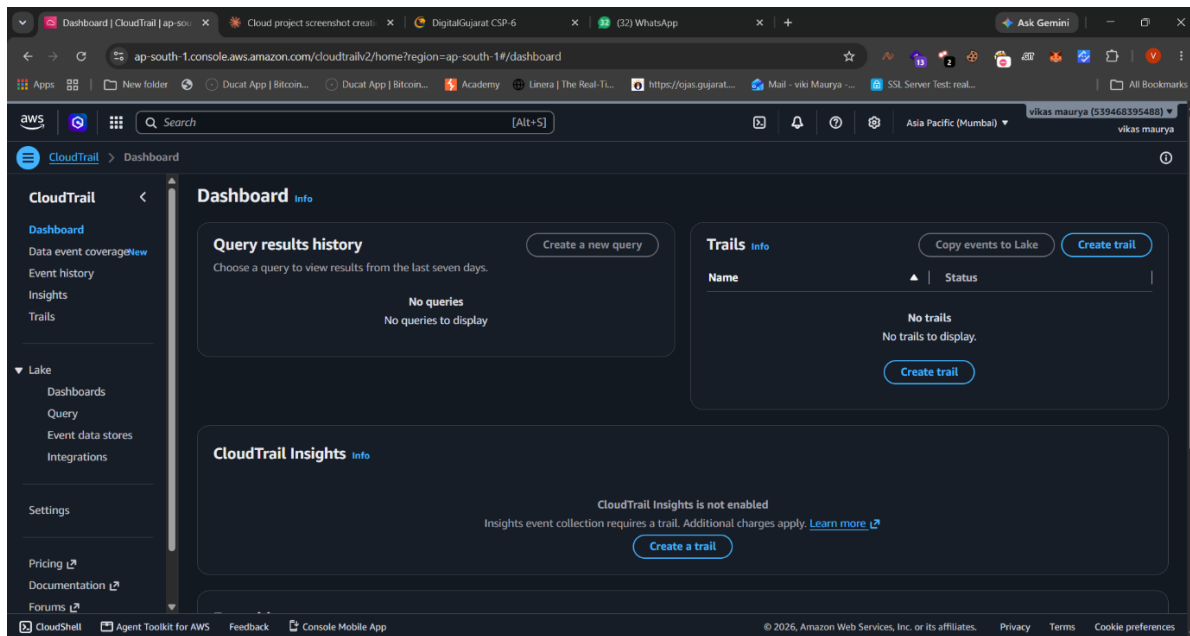


Figure 3. CloudTrail setup used for the simulation

4.2 CloudTrail Trail Details

The trail page shows the configuration used for the exercise. The important details are the trail name, multi-region setting, storage destination, encryption setting and CloudWatch log group. During an investigation, these details help the responder understand where the evidence should exist and whether the logging path itself has been changed.

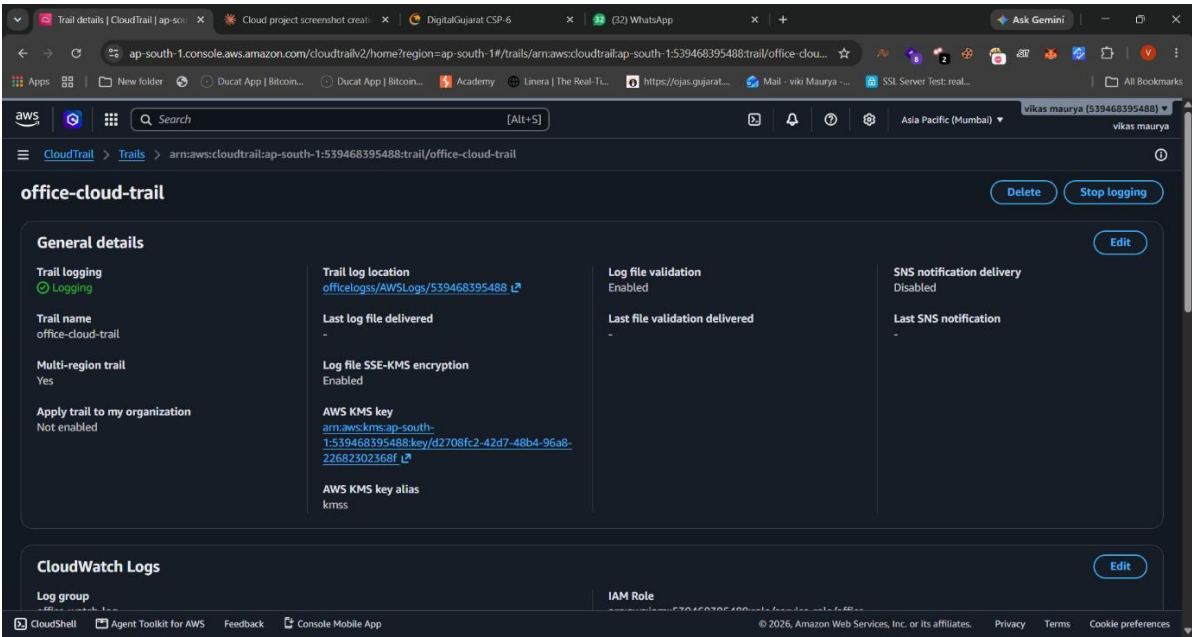


Figure 4. CloudTrail trail details and review screen

The second screenshot on the original page shows the review-and-create stage. This is useful as setup evidence because it confirms that the logging components were part of the environment before the suspicious actions were investigated.

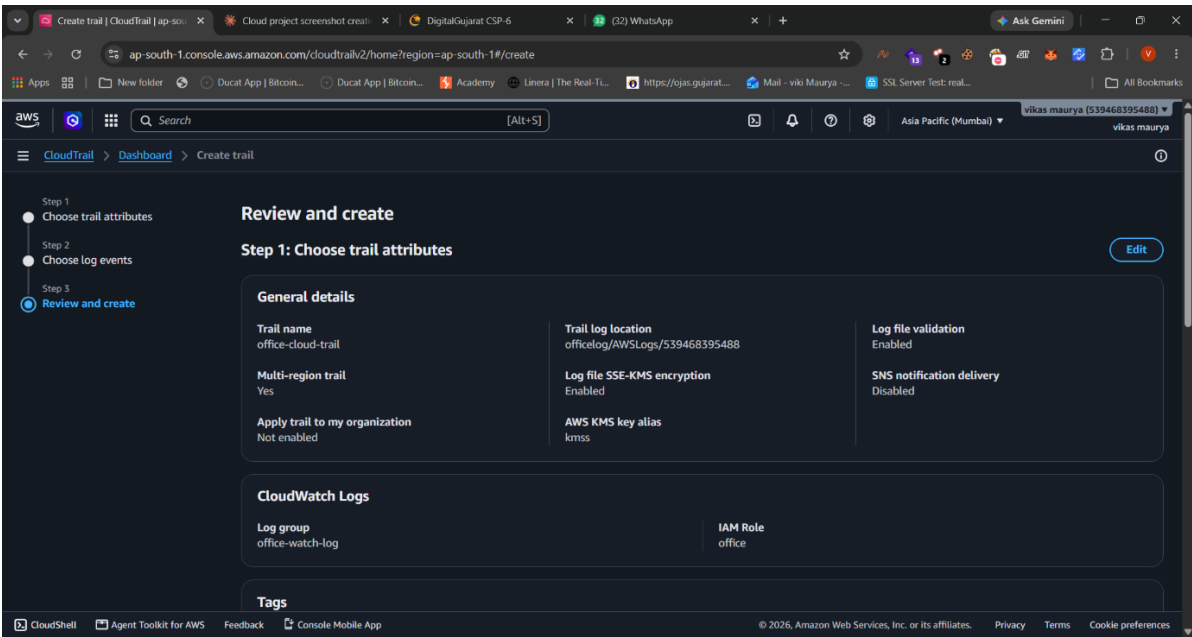


Figure 5. CloudTrail review and creation details

5. S3 Buckets for Logs and Data

Two S3 buckets were used in the exercise. The bucket `officelogss` was used as the CloudTrail log destination. The bucket `officedatas` was used for test data. Keeping logs separate from ordinary test data is important because logs are evidence, while test data is an application or business resource.

The data bucket contained files that became important during the investigation, including `salary-data.txt.txt` and `kiki_credentials.csv`. These filenames were therefore treated as evidence of sensitive data being present in the environment.

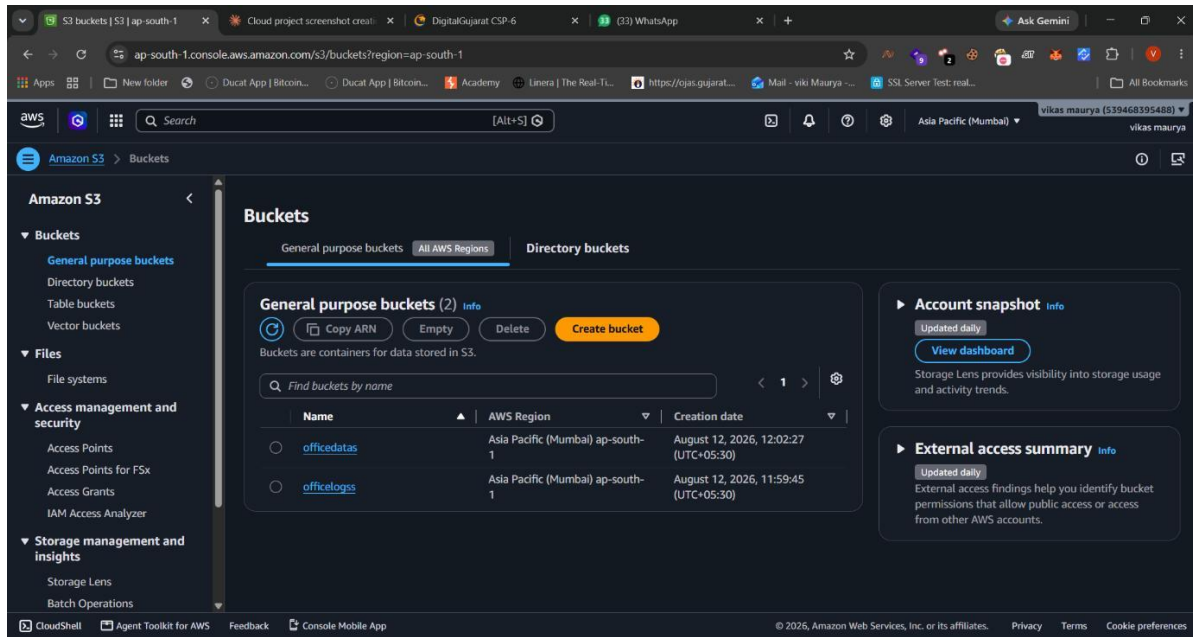


Figure 6. S3 console showing the log and data buckets

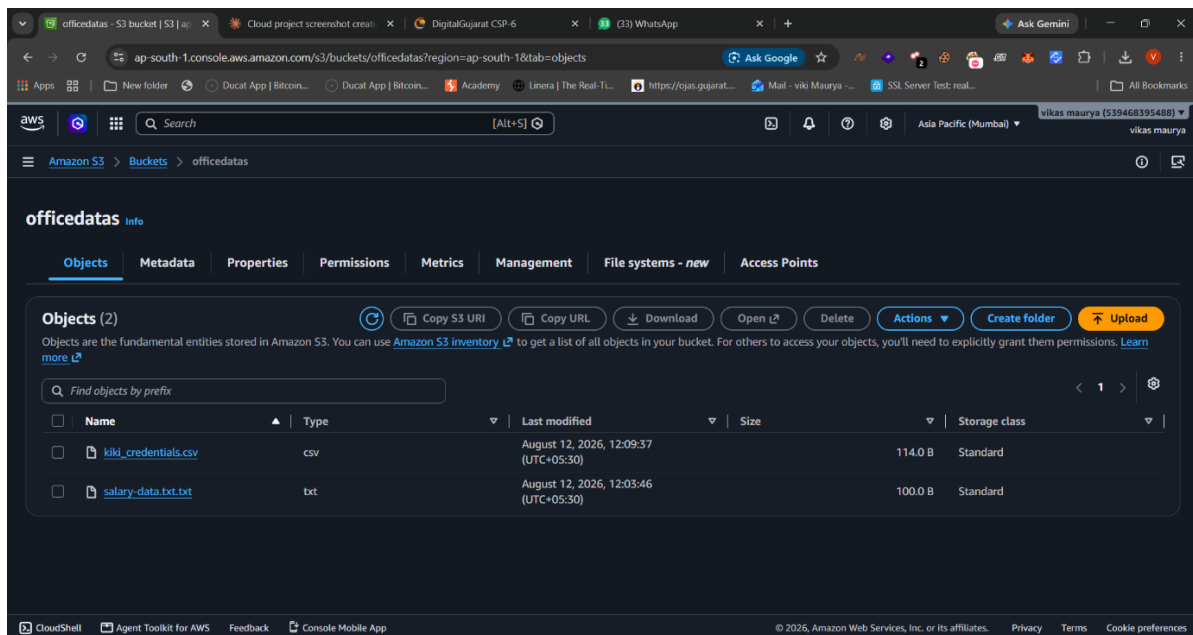


Figure 7. Data bucket and stored objects

5.1 IAM User Setup

Two IAM users were created for the simulation. The user kiki was given AdministratorAccess. The user viki1234 received ReadOnlyAccess. Neither account had MFA enabled, according to the original evidence.

This is an important distinction. ReadOnlyAccess is not the same as full administrative access, but it can still reveal useful information about the environment. In an incident, reconnaissance with read permissions can help an attacker understand what resources exist, what security controls are active and where valuable data may be stored.

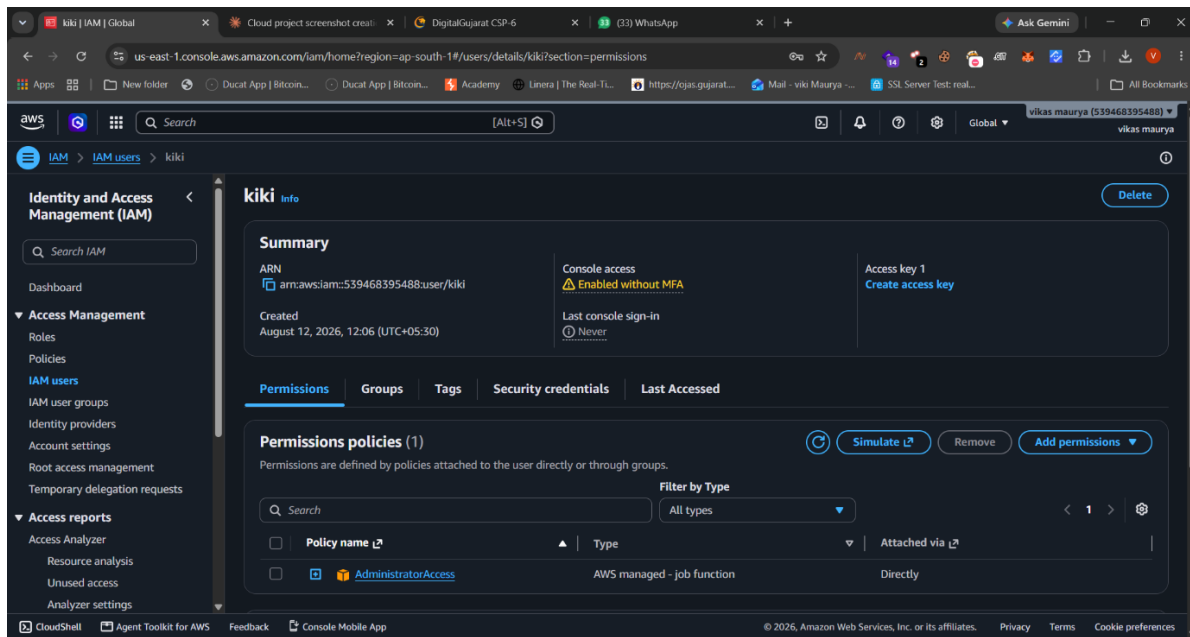


Figure 8. IAM details for user kiki

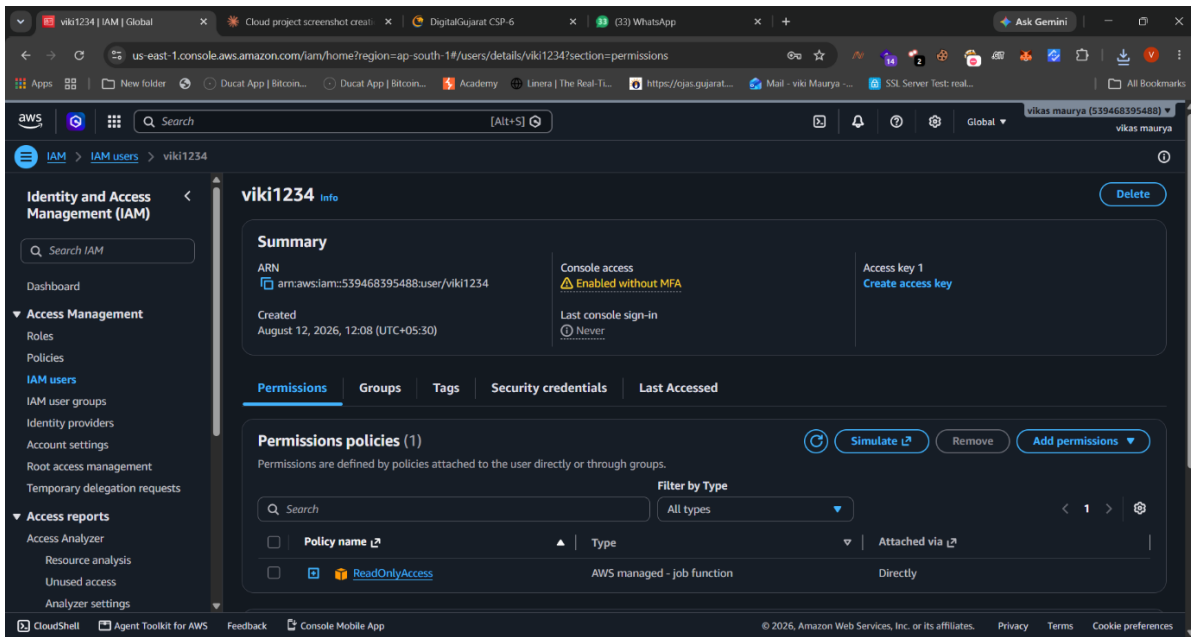


Figure 9. IAM details for user viki1234

The IAM user list shown in the original evidence confirms that the two accounts were present in the environment. This is useful because the later CloudTrail events can be linked back to specific identities instead of being treated as anonymous activity.

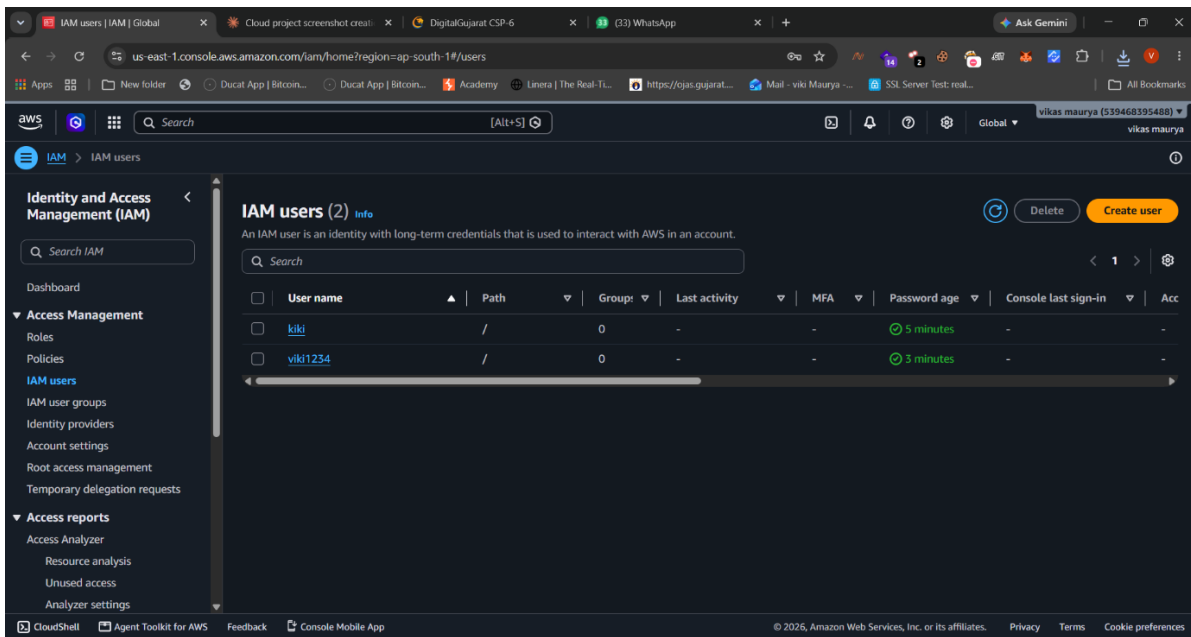
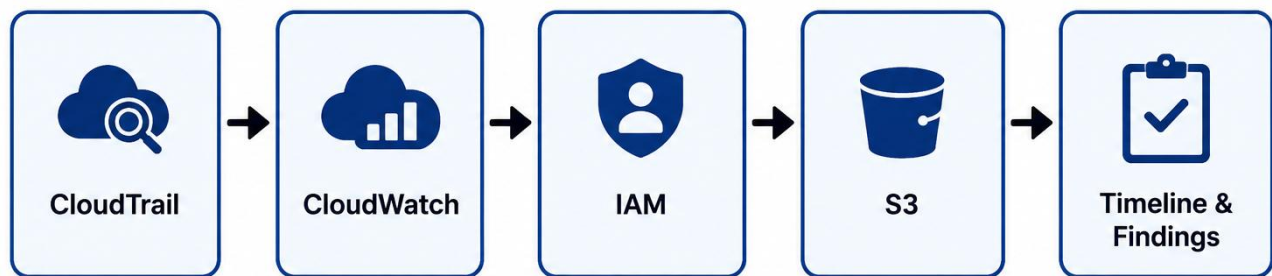


Figure 10. IAM user list showing both accounts

6. Incident Simulation Narrative

The attack story can be understood as a sequence of small actions rather than one large event. First, an identity was created. Next, that identity was given more power. A second account was created for additional access. The second user then explored IAM, S3 and CloudTrail. After that, data-related activity was observed and finally the user attempted to weaken the logging controls.

Investigation Workflow



The investigation was performed from the AWS Management Console.

Figure 11. Investigation workflow used to connect identity, logs and resources

6.1 Initial Foothold

The first important event in the storyline was the creation of the IAM user kiki. The original report treats this as the initial foothold. From an incident response point of view, this is the moment where the attacker gains a new identity inside the cloud environment.

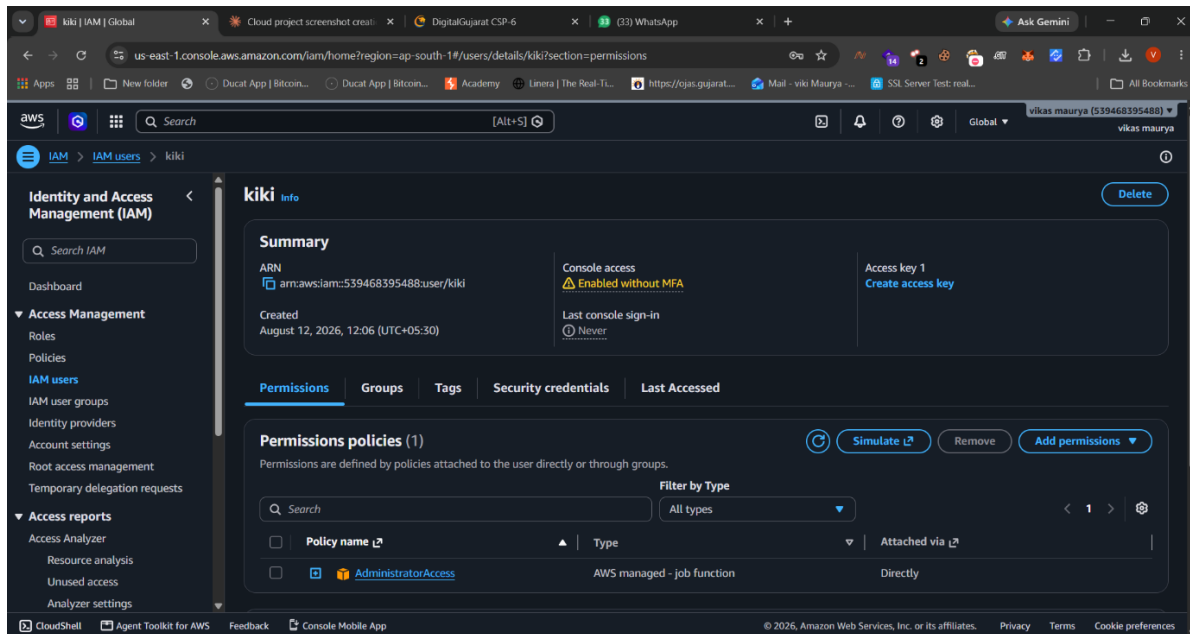


Figure 12. kiki shown with AdministratorAccess attached

The screenshot is important because it connects the user identity with its effective permission set. In simple terms, the identity was not just created; it was created with a level of access that could have a large effect on the account.

6.2 Privilege Escalation

The next step was attaching AdministratorAccess to kiki. In the timeline, this happened immediately after user creation. That fast change is suspicious because it gives a newly created account the ability to perform a wide range of administrative tasks.

For an incident responder, the sequence matters. A CreateUser event by itself may be legitimate. CreateUser followed directly by AttachUserPolicy with AdministratorAccess is a much stronger signal because it shows an increase in control.

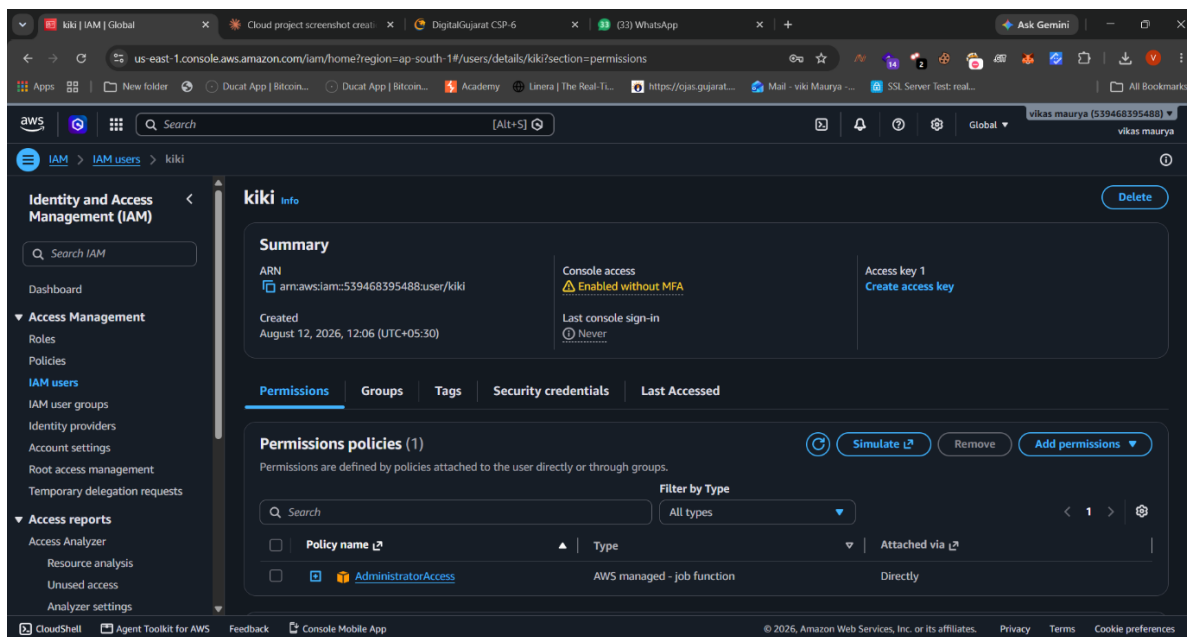


Figure 13. Evidence of AdministratorAccess attached to kiki

6.3 Secondary Foothold and Reconnaissance

A second IAM account, viki1234, was created a short time later. The later activity associated with this account included IAM policy queries, role enumeration, CloudTrail lookups and S3 reconnaissance. This is a classic pattern in which the identity is first established and then used to understand the environment before more sensitive actions are attempted.

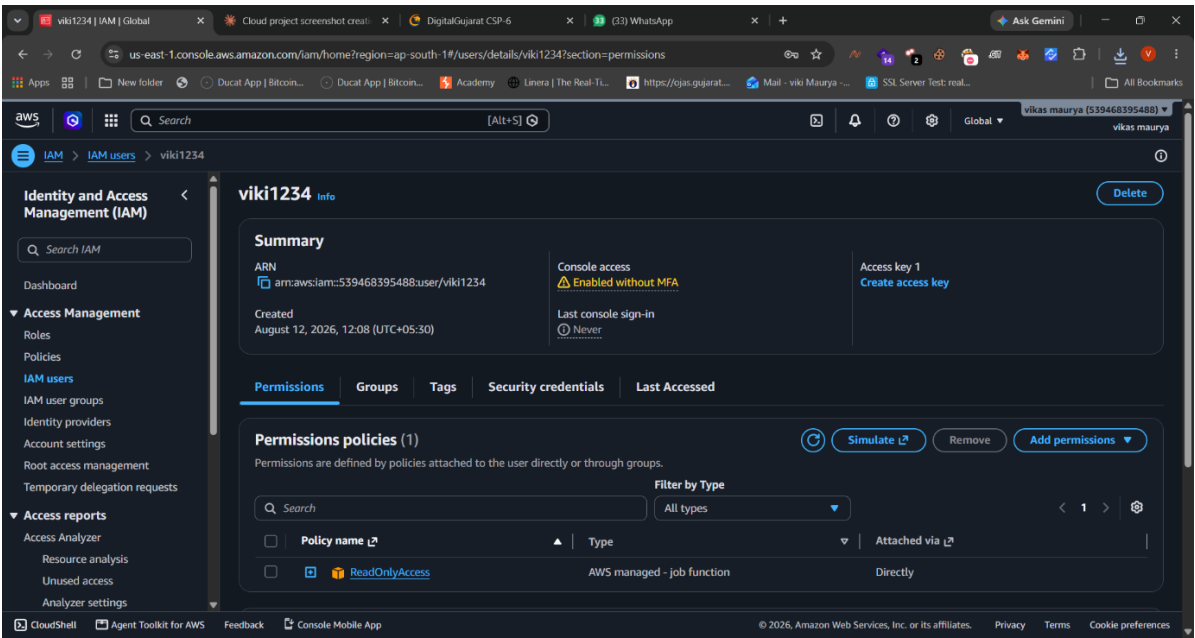


Figure 14. Secondary IAM user viki1234

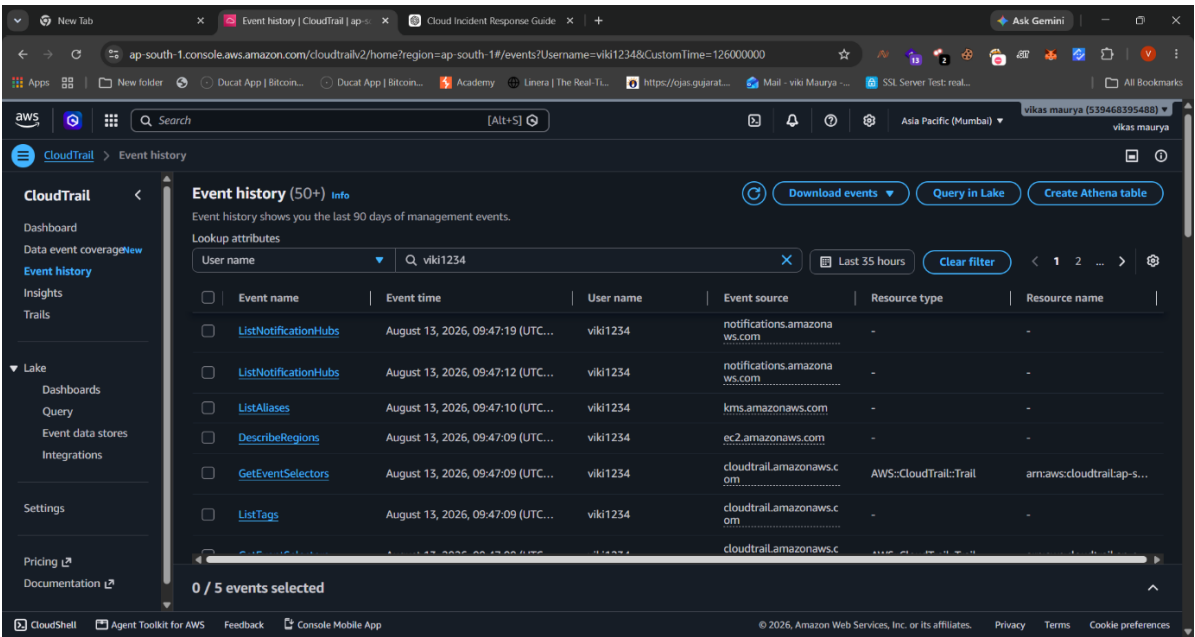


Figure 15. CloudTrail event history showing reconnaissance activity

6.4 Suspicious Data Access

The S3 bucket officedatas contained the files salary-data.txt.txt and kiki_credentials.csv. The original report identifies these objects as sensitive or credential-related test data. Their presence increases the importance of the S3 access events because an attacker who can reach such files may gain useful information or sensitive content.

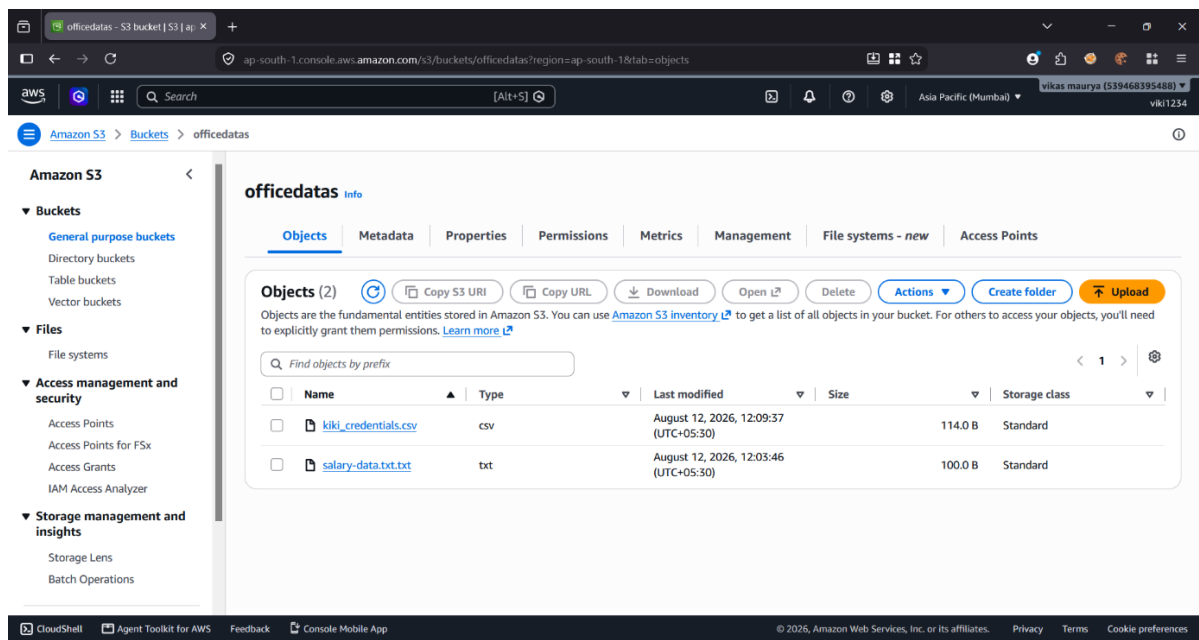


Figure 16. S3 data bucket with the observed objects

The screenshot should be read together with the CloudTrail timeline. The image proves that the files existed in the bucket; the event evidence is what helps explain who interacted with cloud resources around the same period.

6.5 Anti-Forensics Attempts

The most serious part of the storyline is the attempt to interfere with CloudTrail. The events StopLogging and DeleteTrail are strong warning signs during an incident because they can reduce the evidence available to defenders.

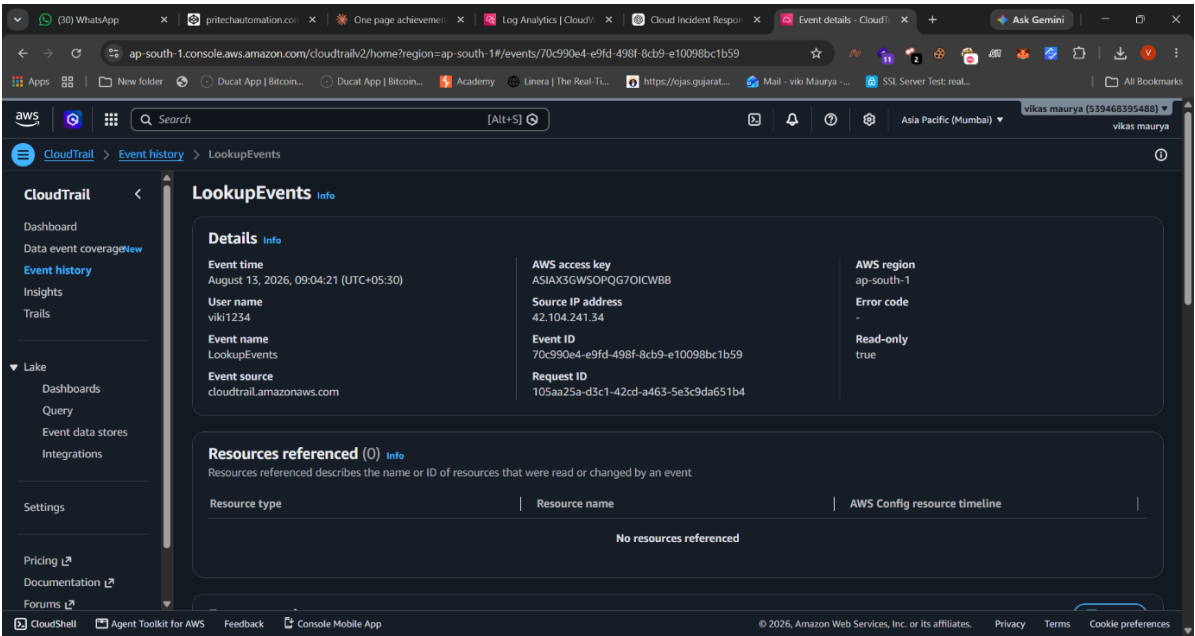


Figure 17. CloudTrail lookup showing logging-related activity

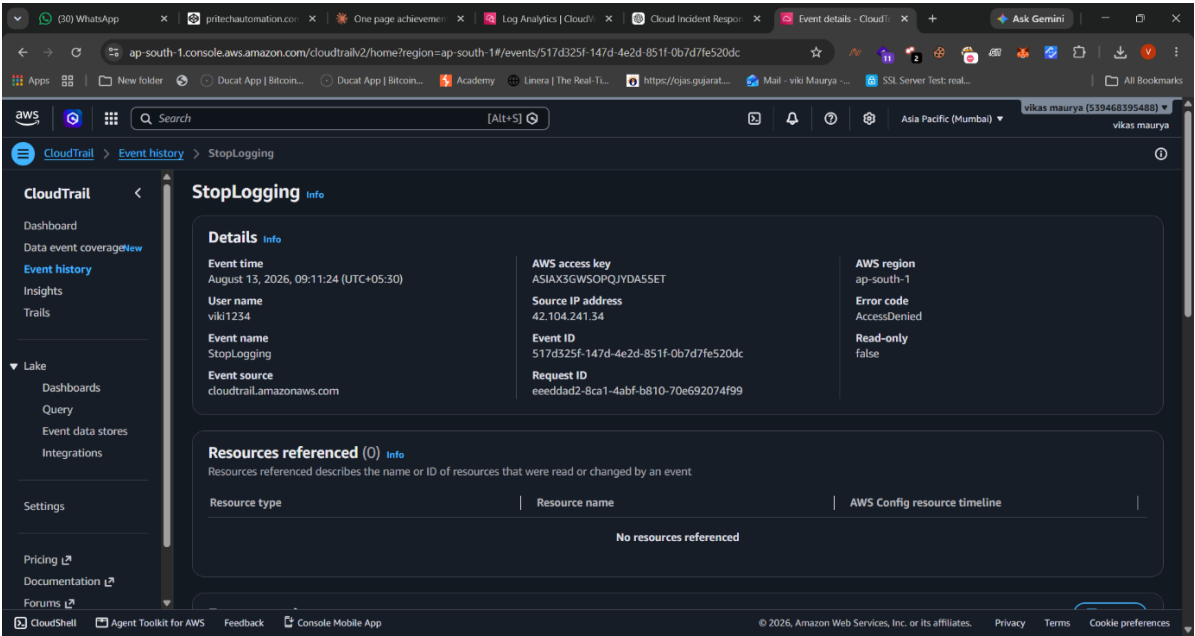


Figure 18. StopLogging event evidence

The supplied timeline shows that one StopLogging attempt was denied, then a DeleteTrail event succeeded, followed by a successful StopLogging event. This sequence is important because it shows that the defensive control was challenged more than once and that at least part of the attack had the desired effect.

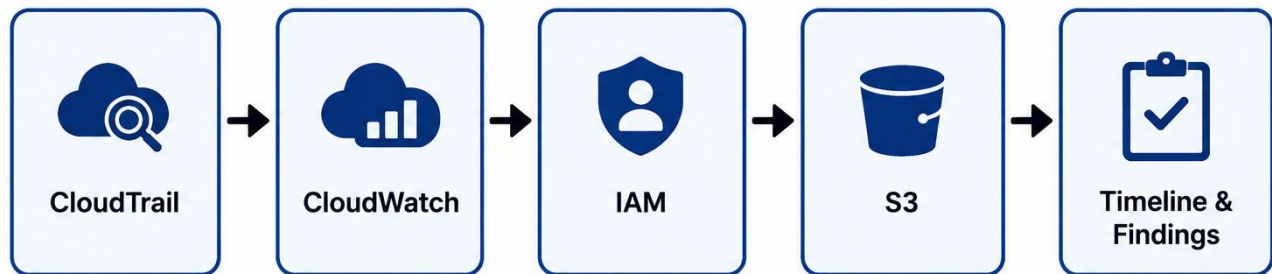
7. Investigation Methodology

The investigation was completed through the AWS Management Console. The responder used four main evidence areas: CloudTrail Event History for event sequence and metadata, CloudWatch Logs Insights for searching log data, S3 for verifying objects, and IAM for confirming users and permissions.

7.1 Investigation Steps

- Start with Event History and identify the suspicious users.
- Filter or inspect important event names such as CreateUser, AttachUserPolicy, StopLogging and DeleteTrail.
- Open detailed event records and record timestamps, user identity and source IP information.
- Check S3 objects to understand what data was available.
- Build a single timeline so each action can be understood in order.
- Separate confirmed actions from assumptions.

Investigation Workflow



The investigation was performed from the AWS Management Console.

Figure 19. Console-based investigation workflow

7.2 Event History Review

The Event History view was used as the first filter. Searching by user and reviewing event names made it possible to isolate the suspicious sequence. The original evidence highlights CreateUser, AttachUserPolicy, StopLogging and DeleteTrail as key events.

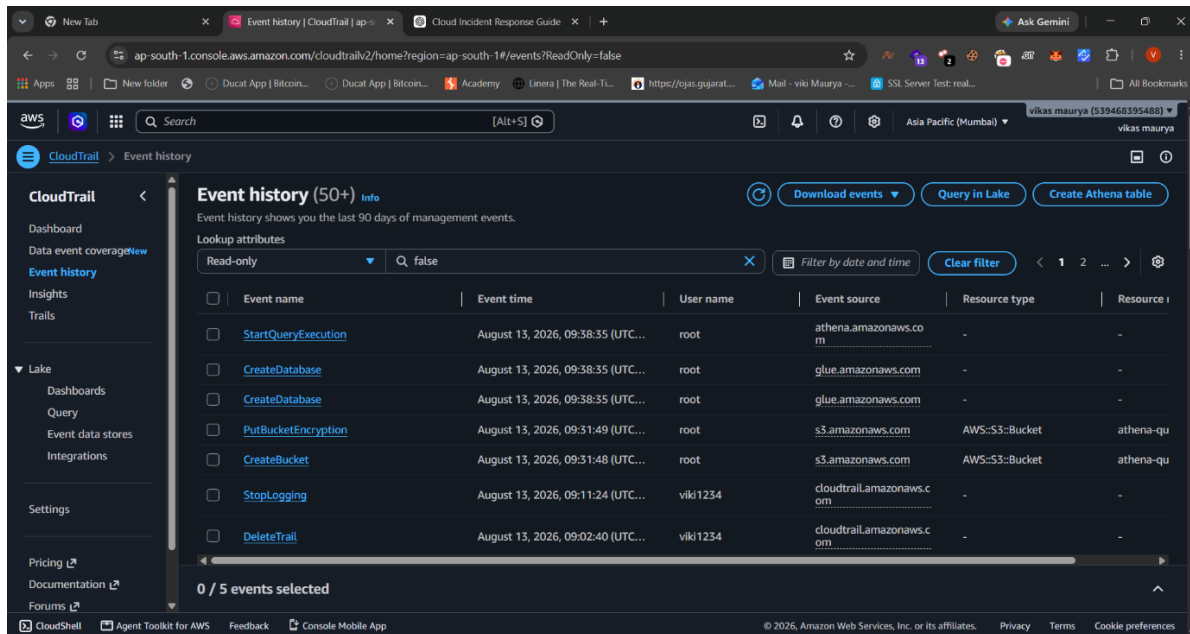


Figure 20. CloudTrail Event History used to isolate suspicious actions

A useful habit in cloud investigations is to avoid reading events in isolation. One event can be normal. A group of events by the same user in a short time window can show the actual story. That is why the report combines identity creation, policy change, reconnaissance and logging tampering.

7.3 Detailed Event Lookup

After finding a suspicious event, the investigator opened the individual record to capture metadata such as the event time, user identity, source IP address, AWS access key and event name. The detailed view provides stronger evidence than a simple list because it lets the responder connect the action to a specific identity and request.

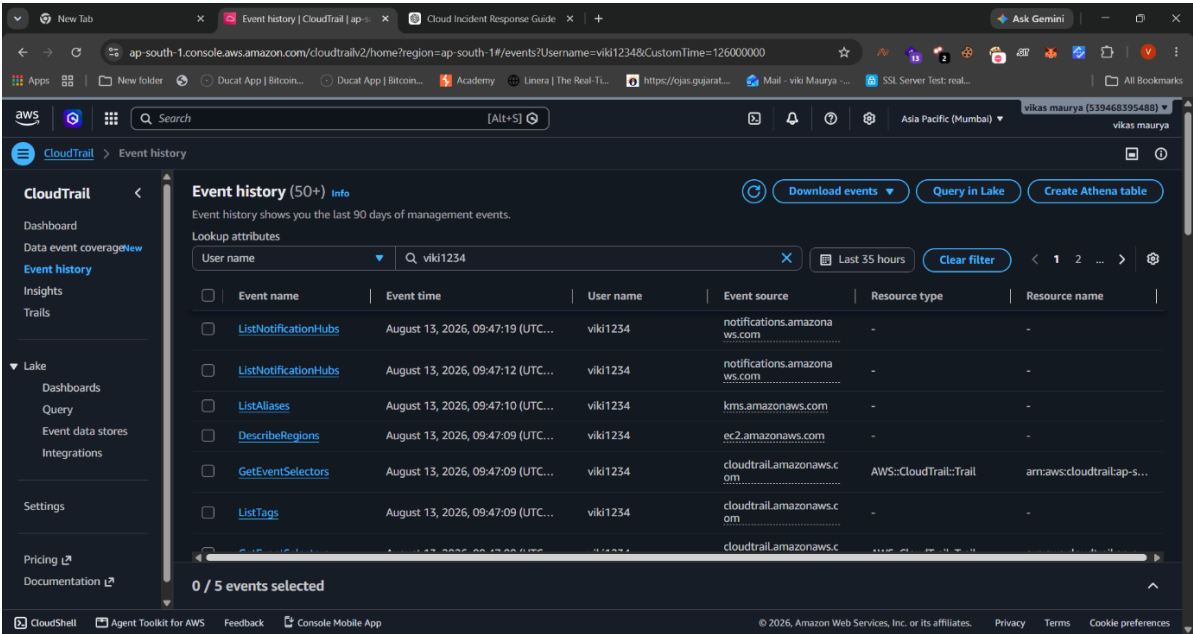


Figure 21. Detailed CloudTrail event record

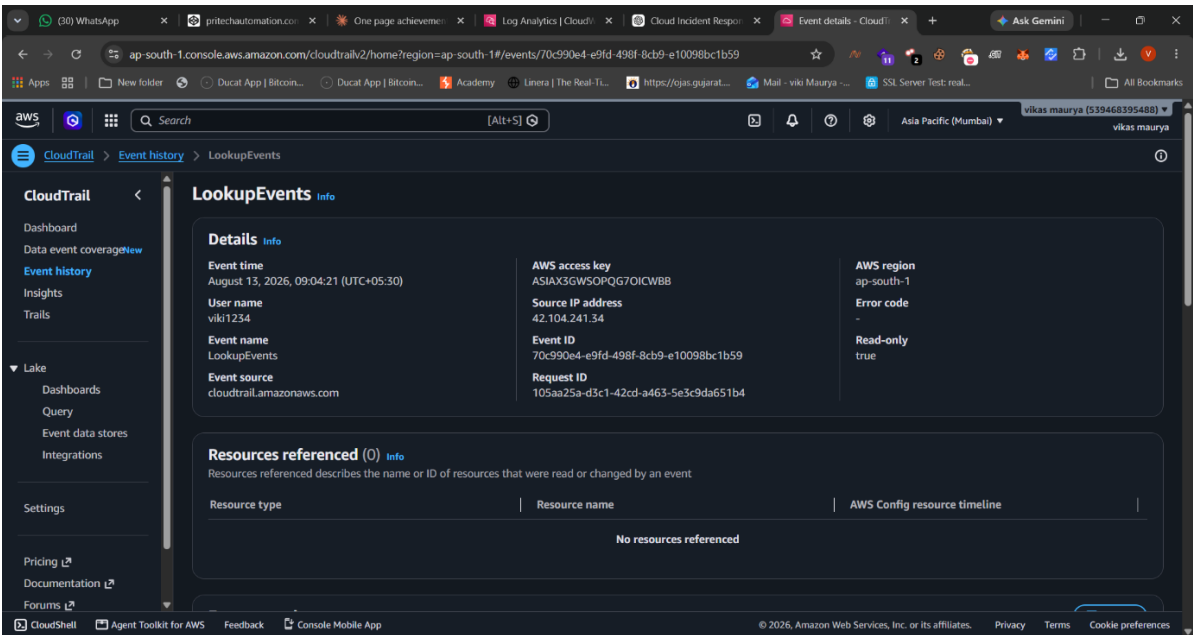


Figure 22. LookupEvents detail used as supporting evidence

7.4 CloudWatch Logs Insights

CloudWatch Logs Insights was used to search the log group office-watch-log. This provided another way to confirm IAM and S3 activity and to look for anti-forensics events. The goal was not simply to run a query, but to test whether the timeline seen in Event History also appeared in the delivered log data.

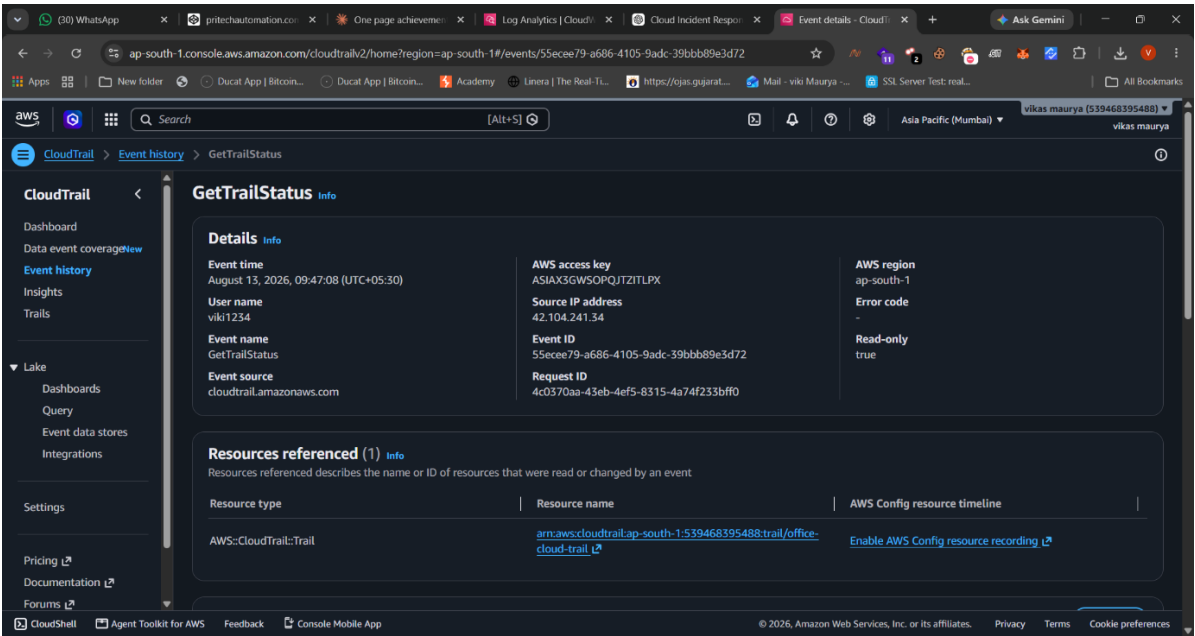


Figure 23. GetTrailStatus and related evidence

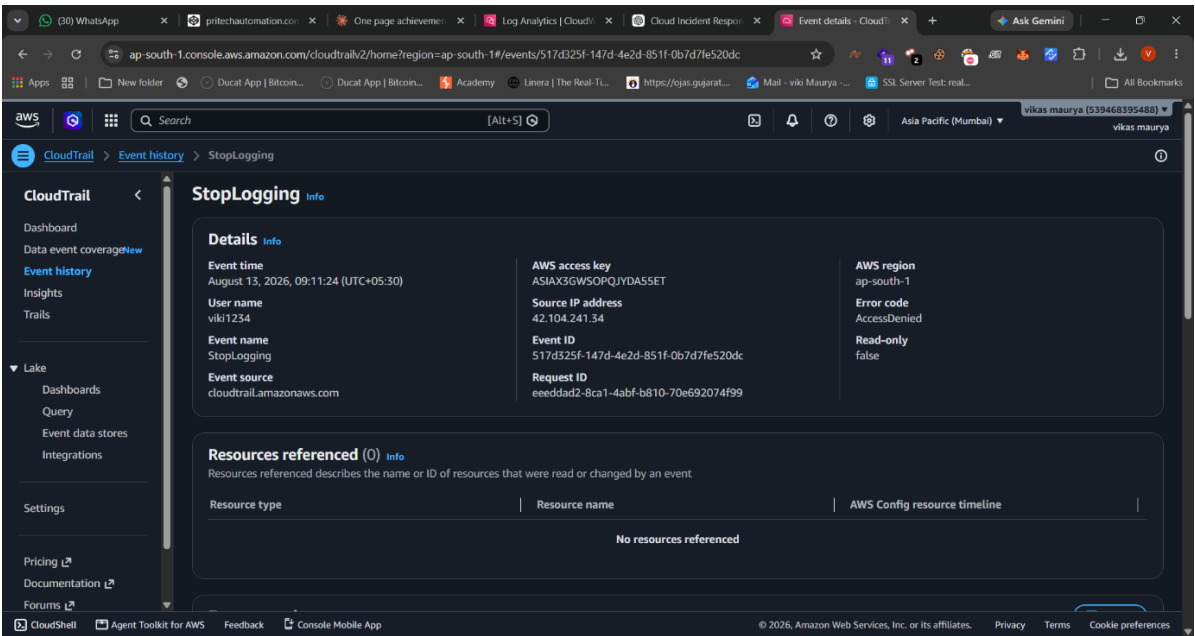


Figure 24. StopLogging evidence in detailed form

7.5 Log Query Evidence

The original project also included CloudWatch query screens. These are useful because they show how the responder moved from a console event list to searchable log records. In a real SOC, this same idea is used to search for a specific event across many accounts or many time periods.

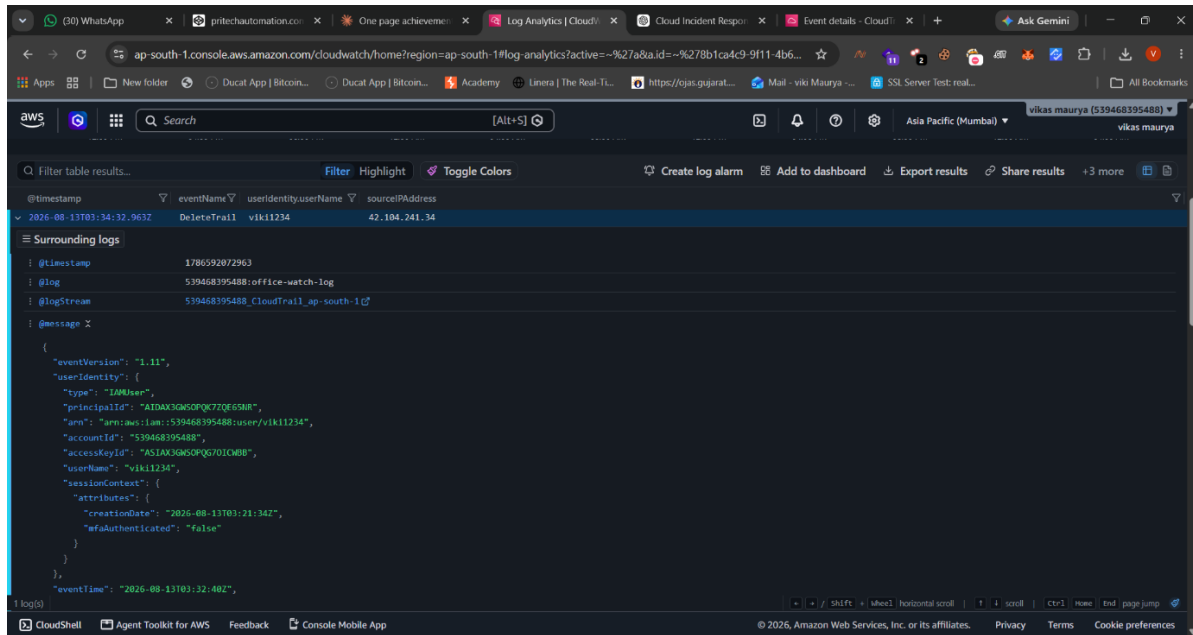


Figure 25. CloudWatch Logs Insights query screen

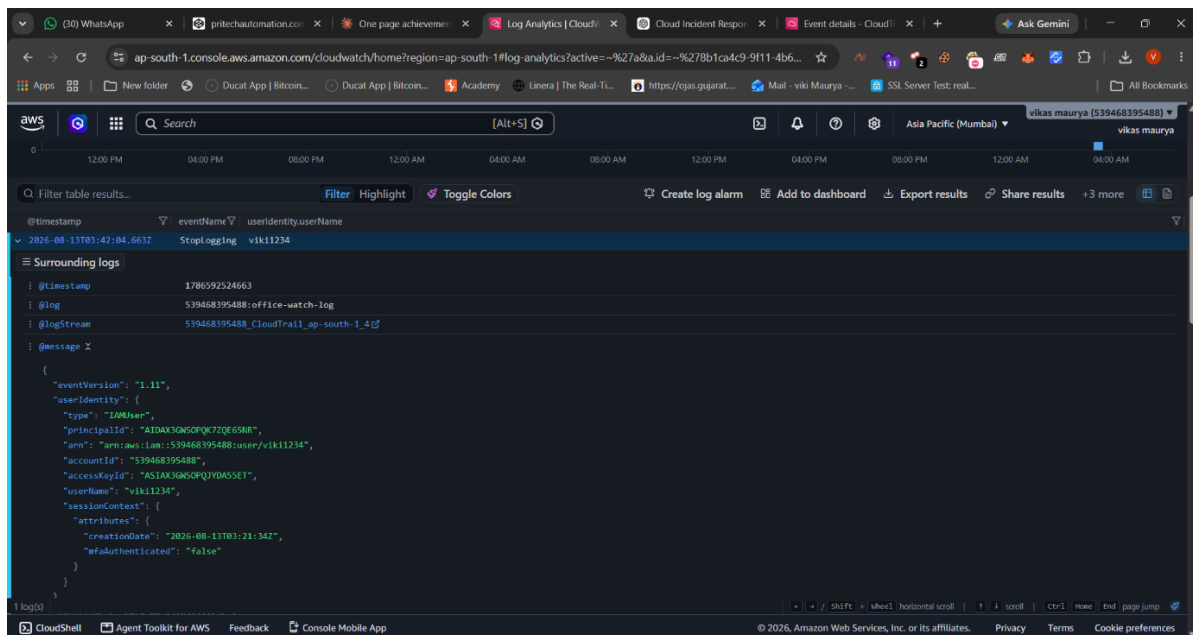


Figure 26. Second query view used during the investigation

@timestamp	eventName	userIdentity.userName
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListAccessKeys	viki1234
2026-08-13T03:41:02.626Z	GetPolicy	viki1234
2026-08-13T03:41:02.626Z	CreateUser	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	GetPolicy	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListGroups	viki1234
2026-08-13T03:41:02.626Z	GetPolicy	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListGroupsForUser	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234
2026-08-13T03:41:02.626Z	ListGroupsForUser	viki1234
2026-08-13T03:41:02.626Z	GetPolicy	viki1234
2026-08-13T03:41:02.626Z	GetPolicy	viki1234
2026-08-13T03:41:02.626Z	ListPolicies	viki1234

Figure 27. Query results showing event activity

@timestamp	eventName	userIdentity.userName
2026-08-13T03:34:32.964Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.964Z	GetBucketObjectLockConfiguration	viki1234
2026-08-13T03:34:32.964Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.964Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.964Z	GetBucketOwnershipControls	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketOwnershipControls	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketVersioning	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:34:32.963Z	GetBucketAcl	viki1234
2026-08-13T03:32:22.559Z	GetBucketOwnershipControls	viki1234
2026-08-13T03:32:22.559Z	GetBucketVersioning	viki1234
2026-08-13T03:32:22.559Z	GetBucketObjectLockConfiguration	viki1234
2026-08-13T03:32:22.559Z	GetBucketOwnershipControls	viki1234
2026-08-13T03:32:22.559Z	GetBucketObjectLockConfiguration	viki1234
2026-08-13T03:32:22.559Z	GetBucketVersioning	viki1234
2026-08-13T03:32:22.559Z	GetBucketAcl	viki1234
2026-08-13T03:32:22.559Z	GetBucketVersioning	viki1234

Figure 28. Additional event results used for comparison

8. Evidence and Timeline Analysis

The timeline is the core of the investigation because it combines separate events into one story. The original report records the timestamps in UTC and associates the events with root/admin activity or the IAM users involved.

Simplified Incident Timeline

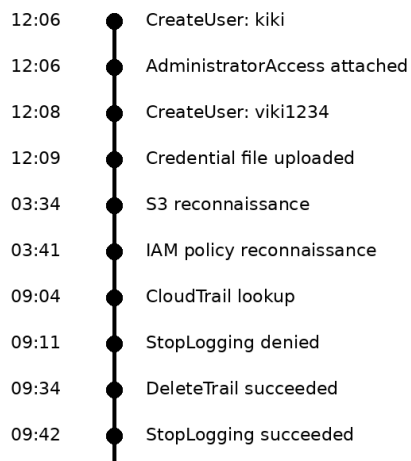


Figure 29. Simplified incident timeline based on the supplied event table

8.1 Key Event Table - Part 1

Time (UTC)	Actor	Action	Resource	Result	Meaning
Aug 12 12:06	Root/Admin	CreateUser	kiki	Success	Initial foothold
Aug 12 12:06	Root/Admin	AttachPolicy	AdministratorAccess -> kiki	Success	Privilege escalation
Aug 12 12:08	Root/Admin	CreateUser	viki1234	Success	Secondary foothold
Aug 12 12:09	IAM:kiki	PutObject	kiki_credentials.csv to officedatas	Success	Credential exposure
Aug 13 03:34	IAM:viki1234	GetBucketAcl / GetBucketVersioning	officedatas	Success	S3 reconnaissance

This table shows how the investigation changes when the events are read as one sequence. User creation alone is not enough to describe the incident. The significance comes from the combination of access creation, privilege change and resource discovery.

8.2 Key Event Table - Part 2

Time (UTC)	Actor	Action	Resource	Result	Meaning
Aug 13 03:41	IAM:wiki1234	ListPolicies / GetPolicy	IAM	Success	Policy reconnaissance
Aug 13 06:46	IAM:wiki1234	GetRole	IAM	Success	Role enumeration
Aug 13 09:02	IAM:wiki1234	ListEventDataStores	CloudTrail	Success	CloudTrail reconnaissance
Aug 13 09:04	IAM:wiki1234	LookupEvents	CloudTrail	Success	Event log reconnaissance
Aug 13 09:11	IAM:wiki1234	StopLogging	CloudTrail	Denied	Failed anti-forensics attempt
Aug 13 09:34	IAM:wiki1234	DeleteTrail	CloudTrail	Denied	Anti-forensics succeeded
Aug 13 09:42	IAM:wiki1234	StopLogging	CloudTrail	Denied	Logging disruption

The second half of the timeline is especially important because the activity moves from reconnaissance to attempts to reduce visibility. That change in behavior increases the confidence that the events should be treated as a coordinated incident sequence.

9. Root Cause Analysis

The evidence points to a combination of identity weakness, excessive privilege and weak logging protection. The first visible weakness was that new IAM users could be created without MFA. The second was that AdministratorAccess was attached to kiki without an approval barrier. The third was the absence of a strong control that would quickly alert the defender when logging itself was changed.

9.1 Main Root Causes

- Weak IAM governance: unauthorized users could be created.
- MFA was disabled on the two accounts.
- Broad administrative permission was attached to a newly created user.
- CloudTrail tampering was possible and was not immediately blocked.
- No automated alert was shown for suspicious IAM or logging changes.

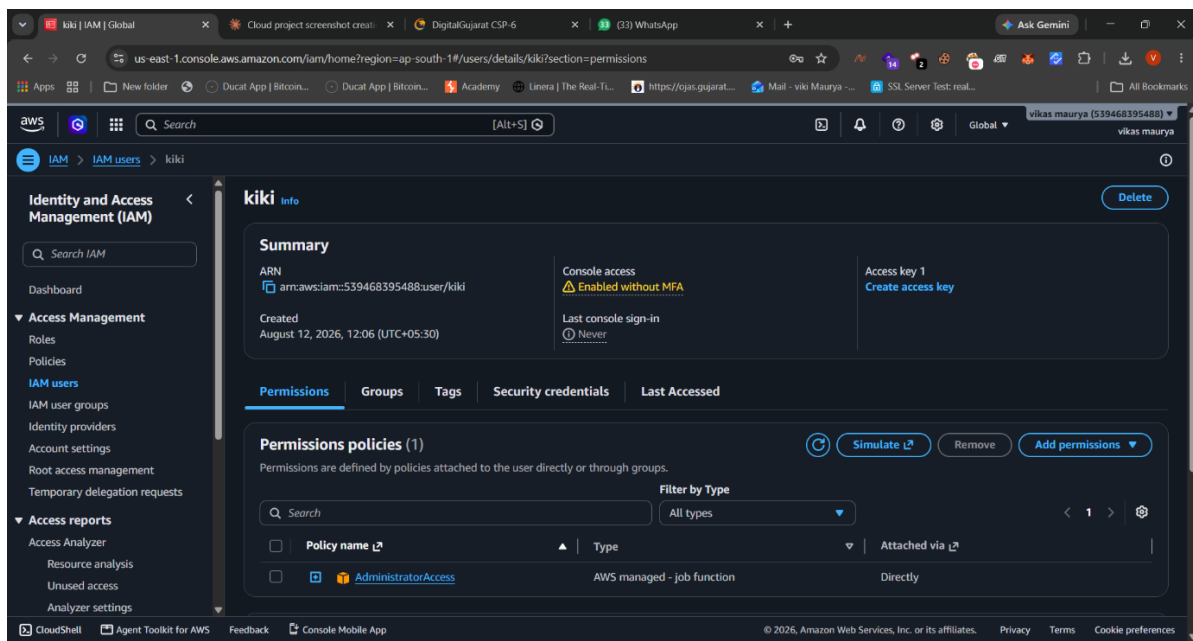


Figure 30. IAM evidence supporting the root cause assessment

9.2 Root Cause Evidence

The second group of screenshots supports the conclusion that the problem was not only a single bad command. The environment allowed several dangerous actions to occur in sequence. This is important because good cloud security is based on layers. Even when one control fails, another control should stop or detect the next risky action.

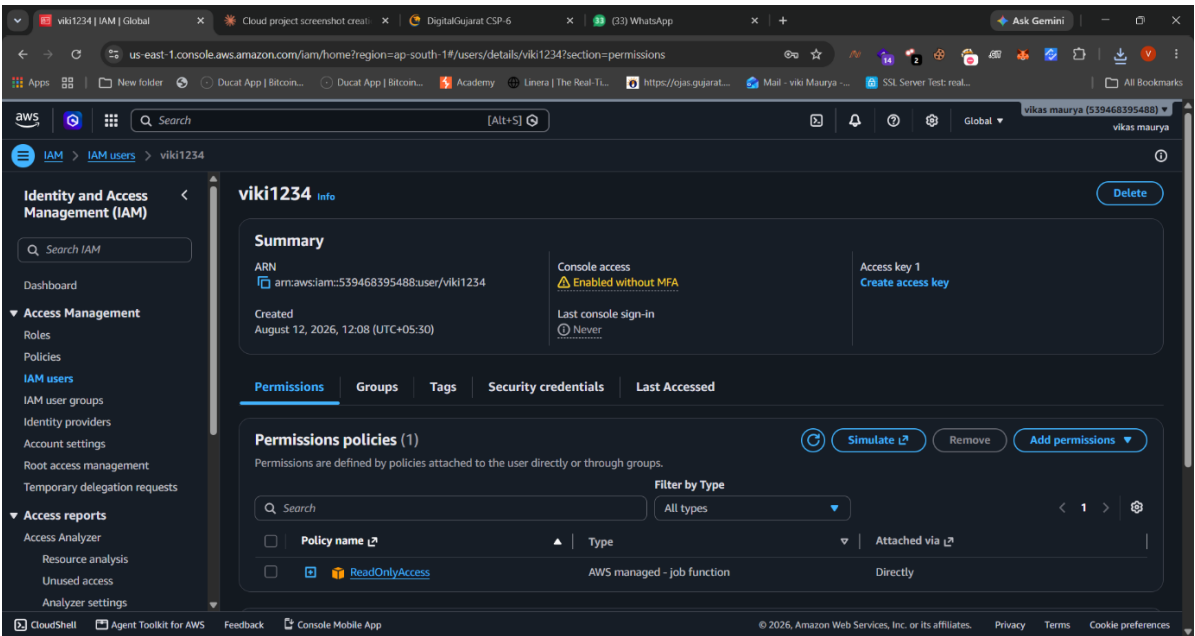


Figure 31. IAM evidence for viki1234

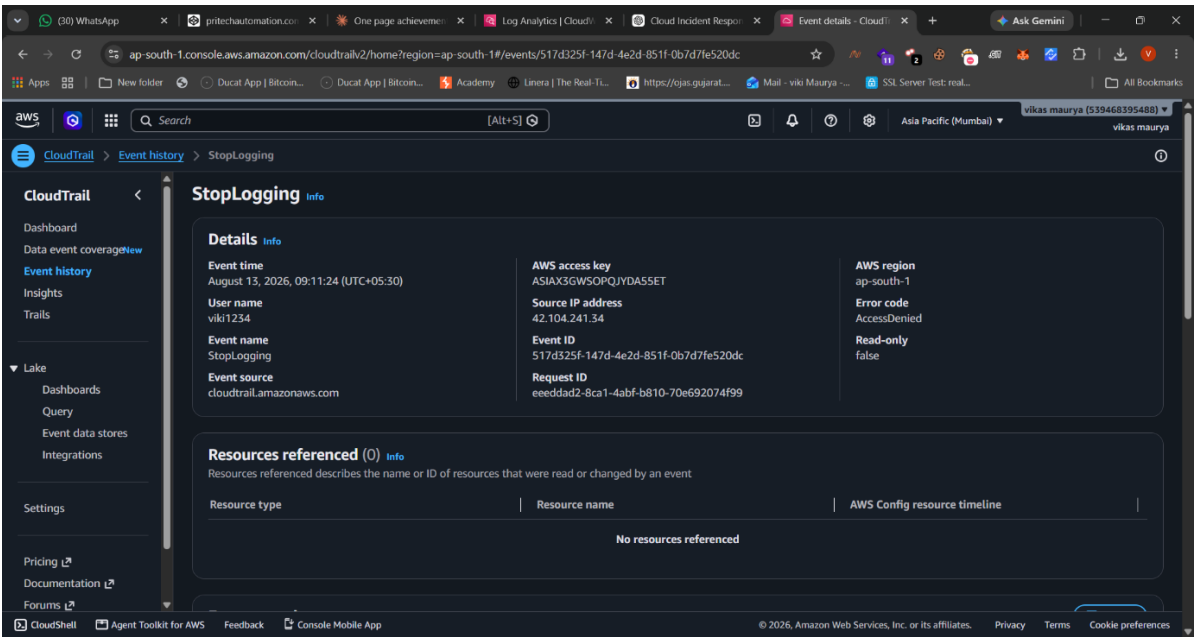


Figure 32. Logging tampering evidence

10. Impact Assessment

The original report identified several successful actions: both IAM users were created, kiki received AdministratorAccess, sensitive test files were present and accessible in S3, and CloudTrail tampering succeeded at least once. These actions create risk in three areas: identity control, data exposure and loss of visibility.

10.1 What Succeeded

- IAM user creation succeeded for kiki and viki1234.
- AdministratorAccess was successfully attached to kiki.
- S3 data objects were present and available.
- DeleteTrail and StopLogging succeeded at later points in the timeline.

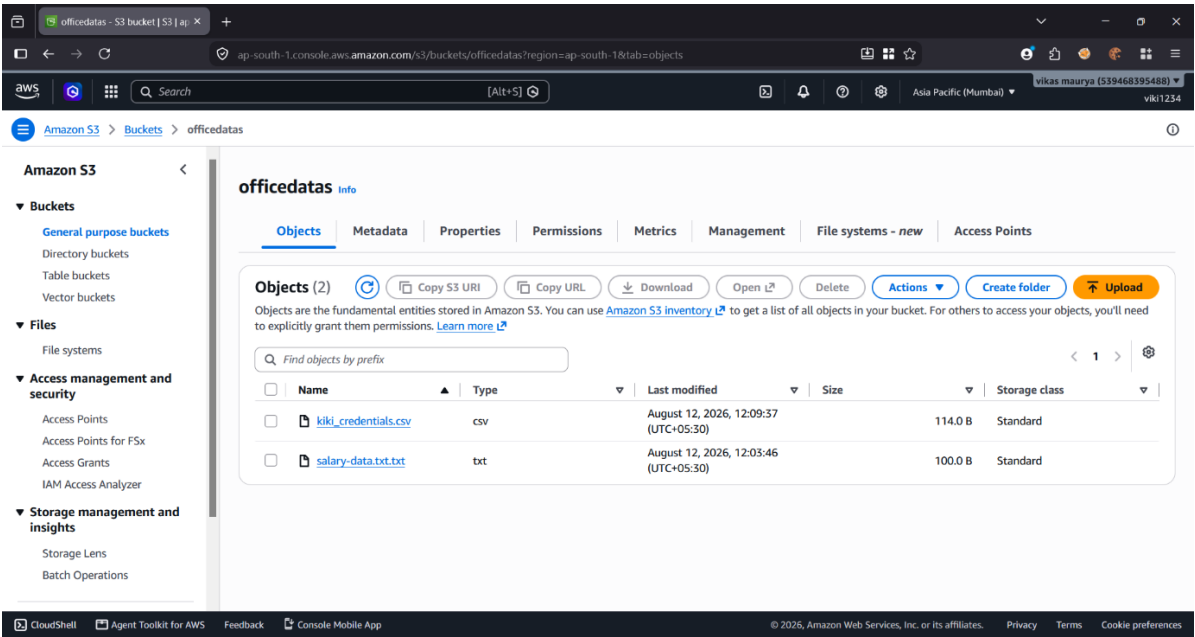


Figure 33. S3 evidence used in the impact assessment

10.2 What Failed and Why It Matters

Not every anti-forensics action succeeded. At least one StopLogging request was denied with AccessDenied. This is an important part of an honest incident report because it shows that some controls were still working. The attacker did not receive full success on every attempt.

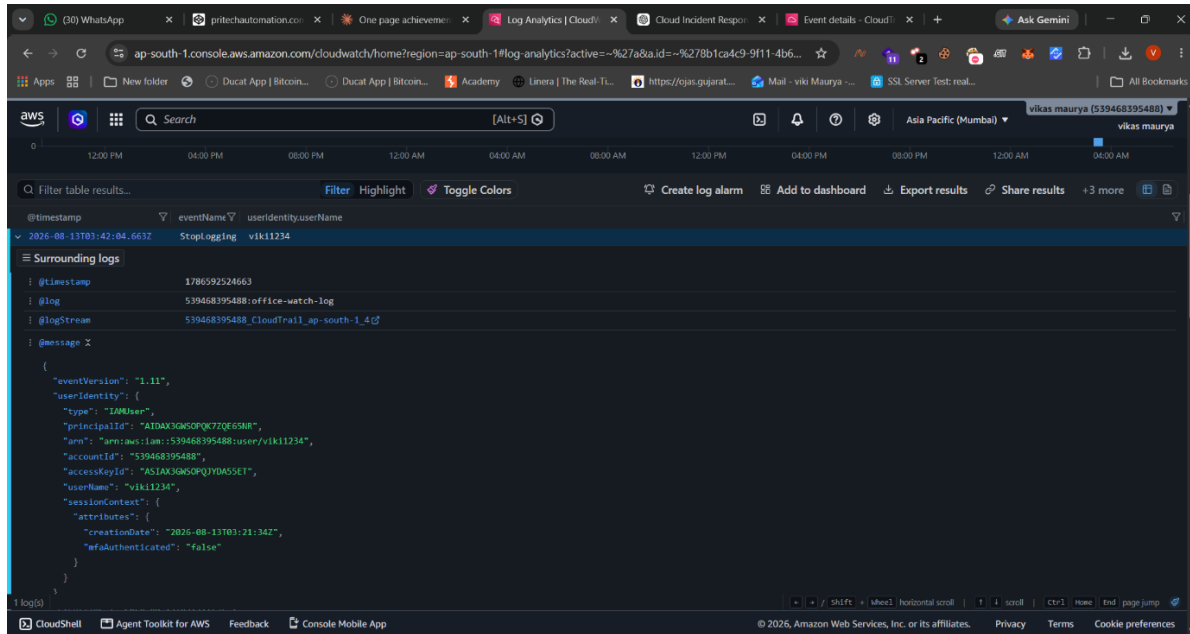


Figure 34. Evidence of a denied StopLogging attempt

10.3 Simulated Business Impact

- Data exposure risk: salary and credential-related files could potentially be copied or disclosed.
- Loss of visibility: logging disruption could delay detection and investigation.
- Privilege escalation risk: an unauthorized user held administrative capability.

11. Indicators of Compromise (IOCs)

The project identified both identity-based and network-based indicators. These are useful during follow-up checks because they give an analyst concrete values to search for across logs.

IOC Type	Value	Context	Why It Matters
IAM user	kiki	AdministratorAccess	MFA disabled
IAM user	viki1234	ReadOnlyAccess	MFA disabled
Source IP	42.104.241.34	Observed with viki1234	Reconnaissance and tampering
S3 bucket	officedatas	Test data	Sensitive objects present
Object	salary-data.txt.txt	Sensitive data	Observed in S3
Object	kiki_credentials.csv	Credential-related file	Observed in S3

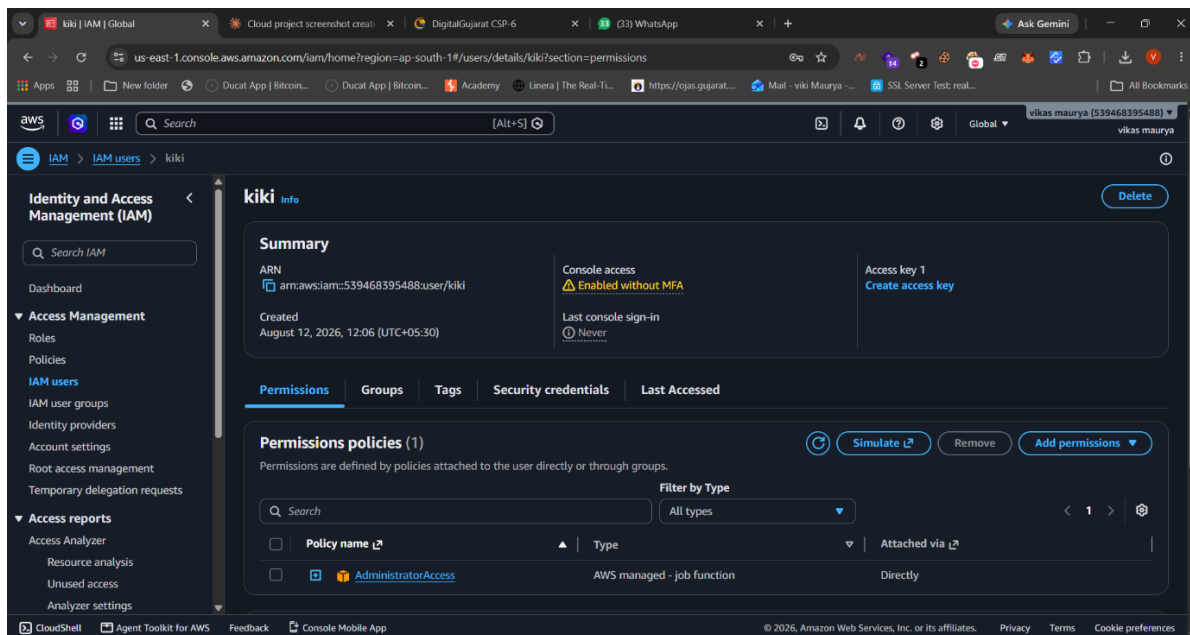


Figure 35. IAM IOC evidence

11.1 Access Keys and Source IP Evidence

The original report records an access key observed in CloudTrail in association with viki1234 and the source IP 42.104.241.34. In an operational environment, these values would be useful for retrospective searching, credential revocation and correlation with other logs.

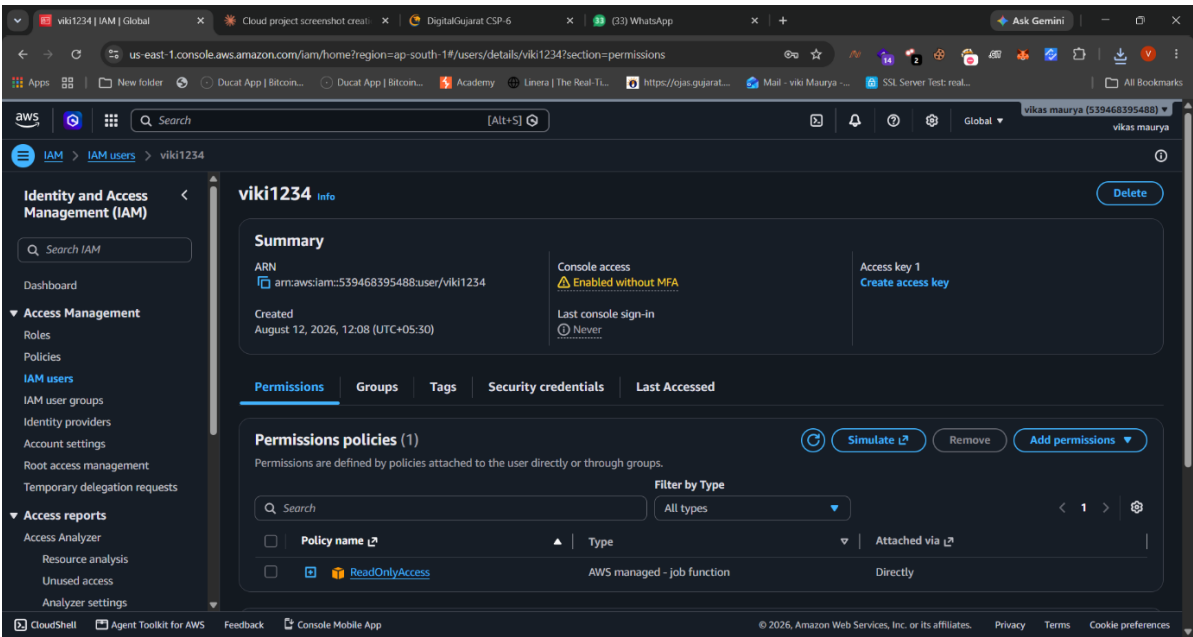


Figure 36. Access key evidence in CloudTrail

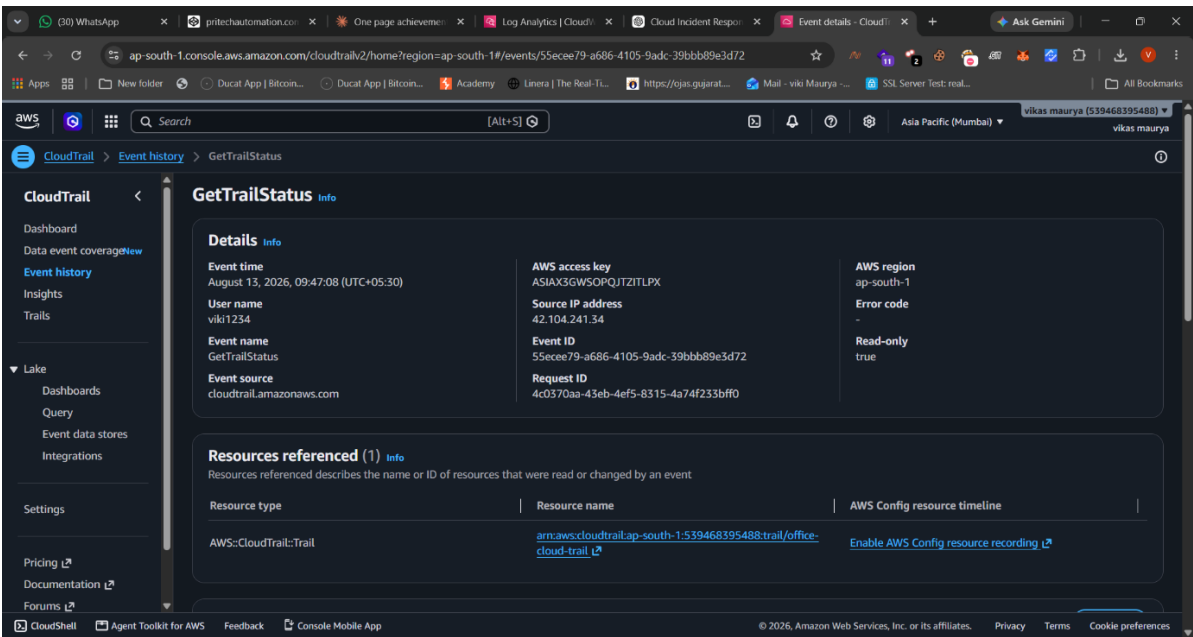


Figure 37. Additional identity evidence

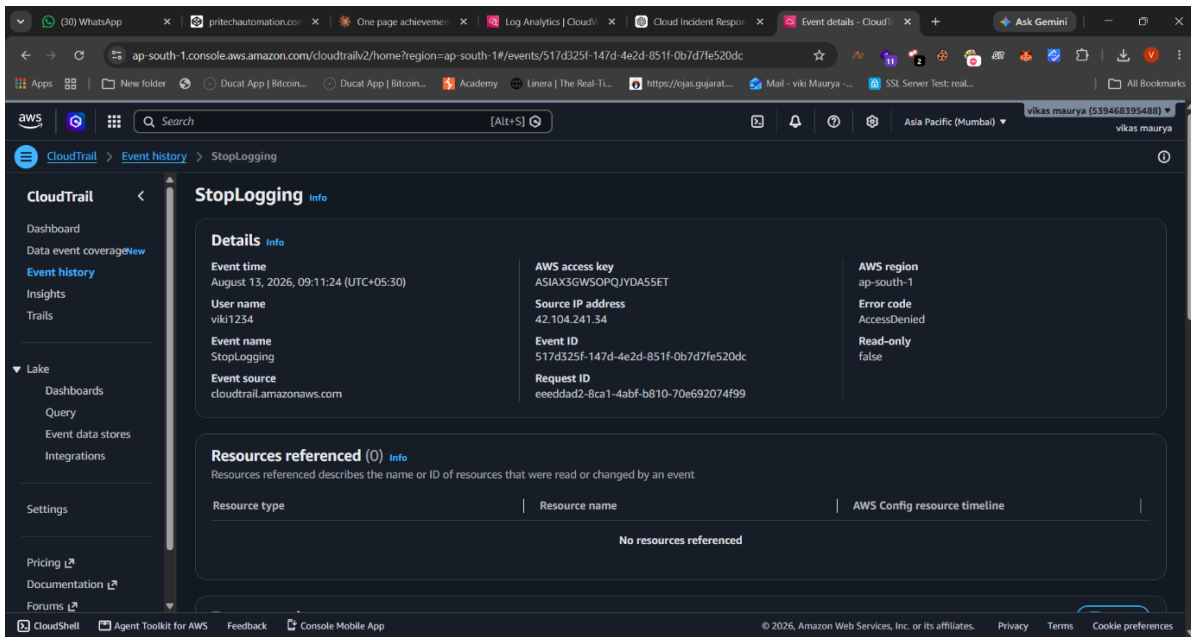


Figure 38. Source IP and CloudTrail tampering evidence

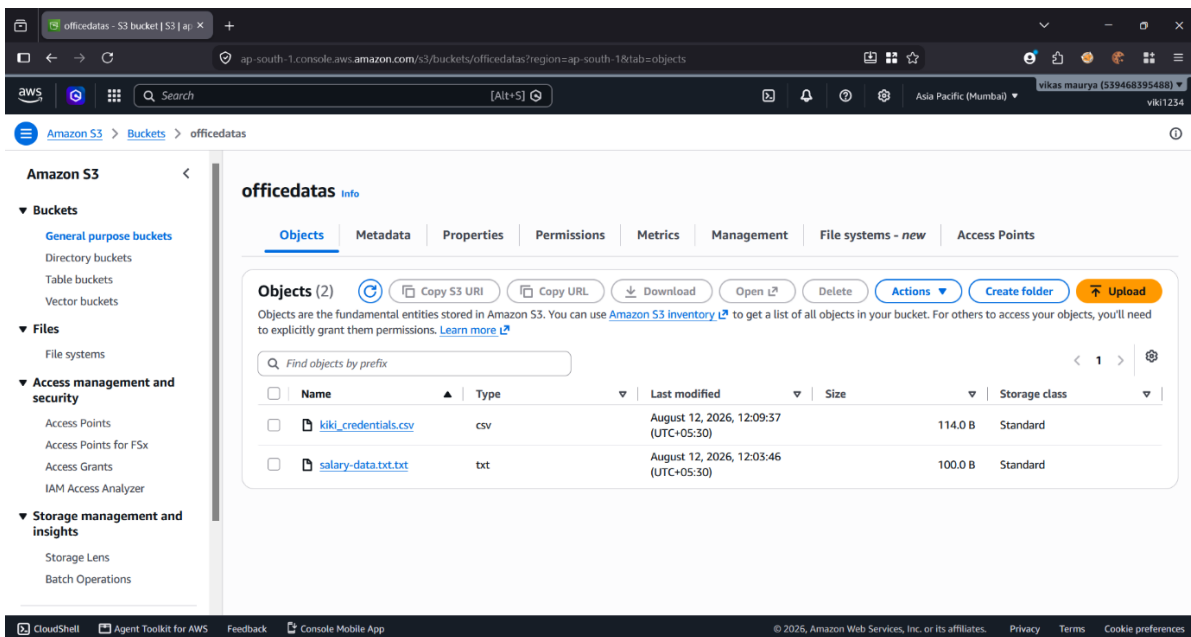


Figure 39. S3 objects associated with the investigation

12. Remediation Recommendations

12.1 Immediate Containment

- Delete the unauthorized IAM users kiki and viki1234 after evidence is preserved.
- Revoke or disable associated access keys.
- Re-enable and validate CloudTrail logging.
- Confirm the expected trail and delivery destinations.
- Review the officedatas bucket and remove or secure sensitive test files.
- Review credentials that may have been exposed and rotate them.

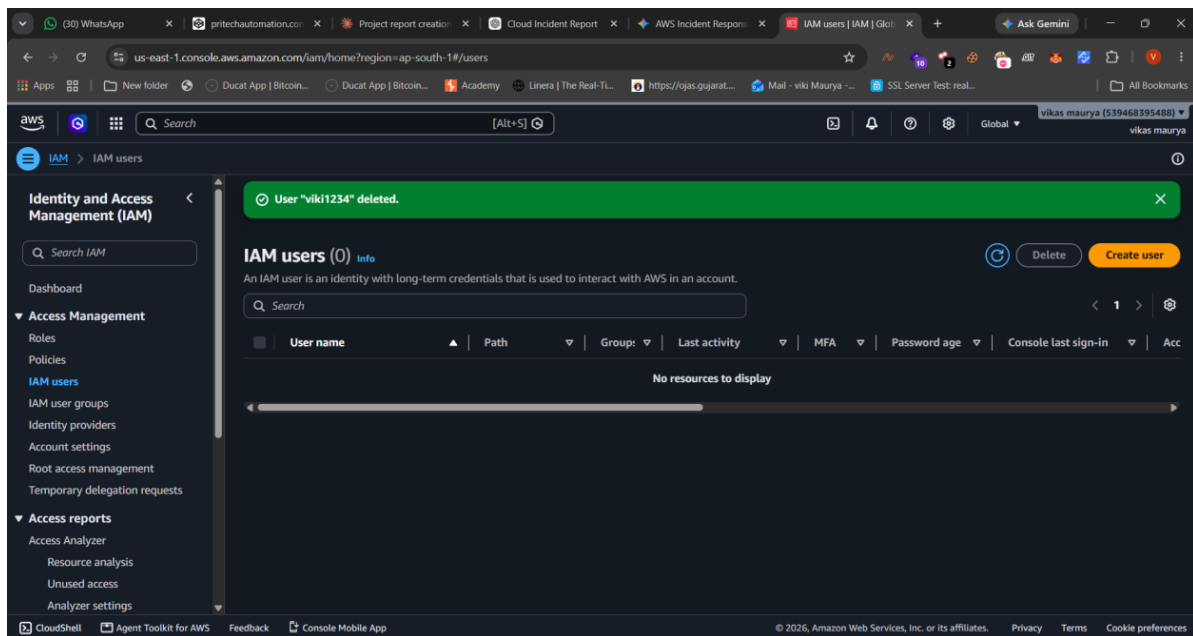


Figure 40. Evidence of IAM cleanup in the containment stage

12.2 Long-Term Hardening

- Enforce MFA for all IAM identities that require console access.
- Use least privilege instead of broad administrator policies.
- Restrict who can create users and attach high-privilege policies.
- Protect CloudTrail configuration from unauthorized modification.
- Review S3 permissions and sensitive data storage regularly.
- Rotate credentials and remove unused access keys.

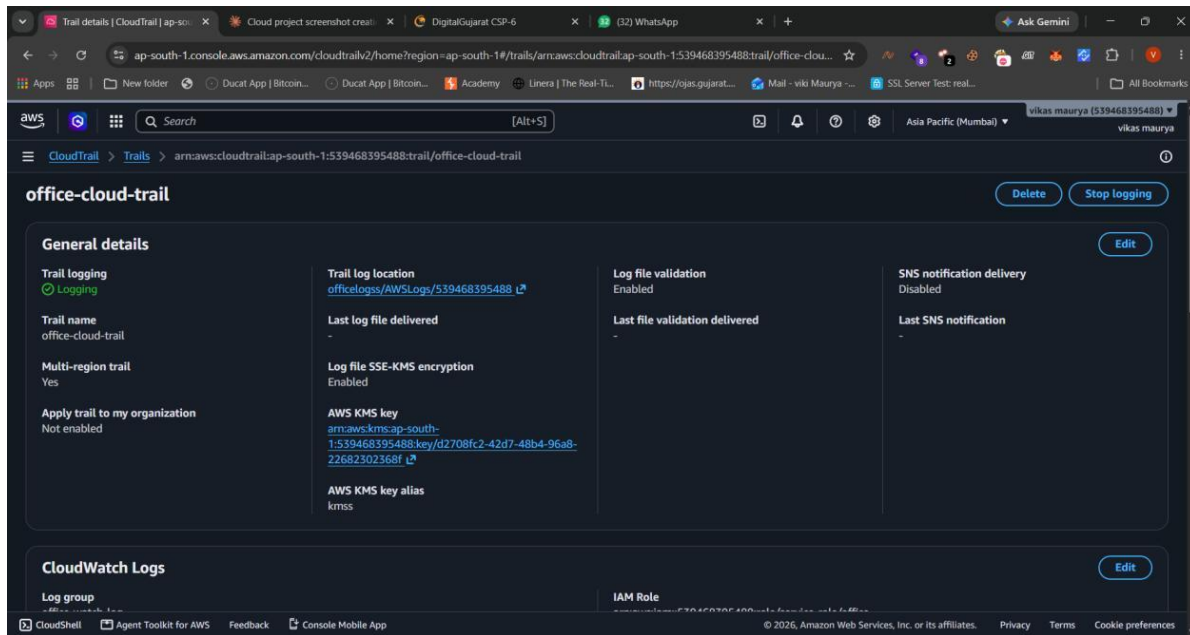


Figure 41. Logging and remediation configuration evidence

13. Detection and Monitoring Improvements

The most important detection gap in the project was the lack of a fast alert when a new IAM user was created or when CloudTrail was changed. A responder should not have to discover these events only after a later investigation.

13.1 Recommended High-Value Alerts

- IAM: CreateUser
- IAM: AttachUserPolicy with AdministratorAccess
- IAM: CreateAccessKey
- CloudTrail: StopLogging
- CloudTrail: DeleteTrail
- S3: unusual access to sensitive objects
- New console login or access from an unexpected source IP

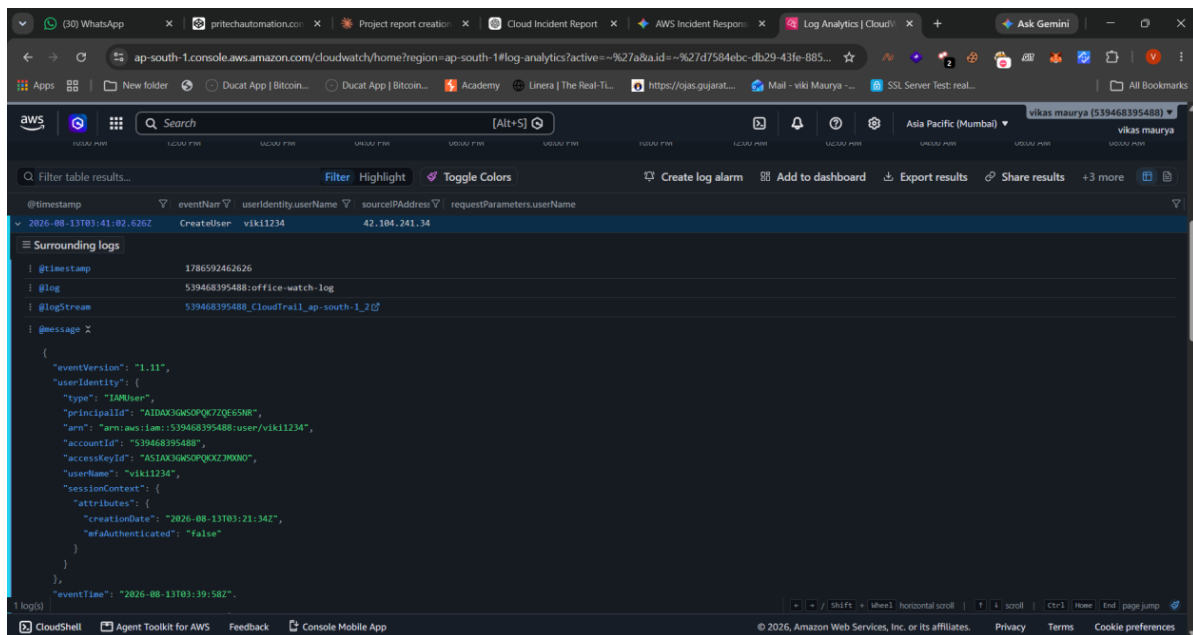


Figure 42. CloudWatch query evidence supporting monitoring improvements

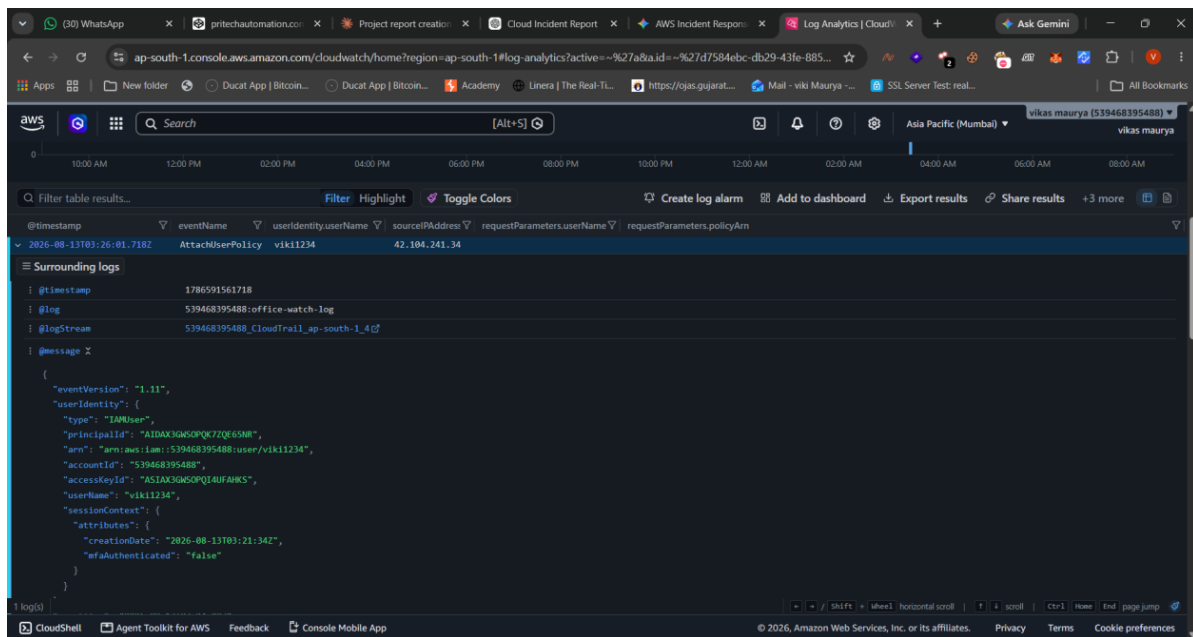


Figure 43. Additional monitoring evidence from the project

13.2 Simple Detection Design

A practical detection rule for this exercise would start with a small set of high-risk event names. The alert should include the event time, user identity, source IP, event name and affected resource. That information gives the analyst enough context to decide whether the action is expected or suspicious.

Event	What It Means	Suggested Priority
CreateUser	New IAM identity created	Medium to High
AttachUserPolicy	Permission level changed	High
CreateAccessKey	Programmatic credential created	High
StopLogging	Logging disabled	Critical
DeleteTrail	Trail removed	Critical

13.3 Security Services and Continuous Monitoring

- Enable **AWS GuardDuty** for continuous threat detection.
- Enable **AWS Security Hub** for centralized security findings.
- Use **CloudTrail** to record all AWS account activities.
- Use detection services to identify suspicious events from CloudTrail logs.
- Combine **logging and threat detection** for better security monitoring.
- Continuously monitor the AWS environment for abnormal activities.
- Review security findings regularly and respond quickly to incidents.

14. Lessons Learned

14.1 Identity Security

- Enable **Multi-Factor Authentication (MFA)** for all IAM users.
- Follow the **Principle of Least Privilege (PoLP)**.
- Avoid granting unnecessary administrative permissions.
- Regularly review IAM users, groups, and policies.
- Monitor privileged account activities using CloudTrail.

14.2 Logging Security

- Treat CloudTrail logs as critical security evidence.
- Protect logs from unauthorized modification or deletion.
- Store logs in a secure and separate S3 bucket.
- Enable log integrity validation where applicable.
- Monitor logging services continuously for tampering attempts.
- Restrict access to logging resources using IAM policies.

- **14.3 Data Security**

- Do not store sensitive information in public or shared S3 buckets.
- Protect confidential files using encryption.
- Apply least-privilege access to S3 buckets.
- Enable bucket logging and monitoring.
- Regularly review bucket permissions and access logs.
- Secure sensitive data such as credentials, salary records, and personal information.
- Follow AWS security best practices even in sandbox environments.

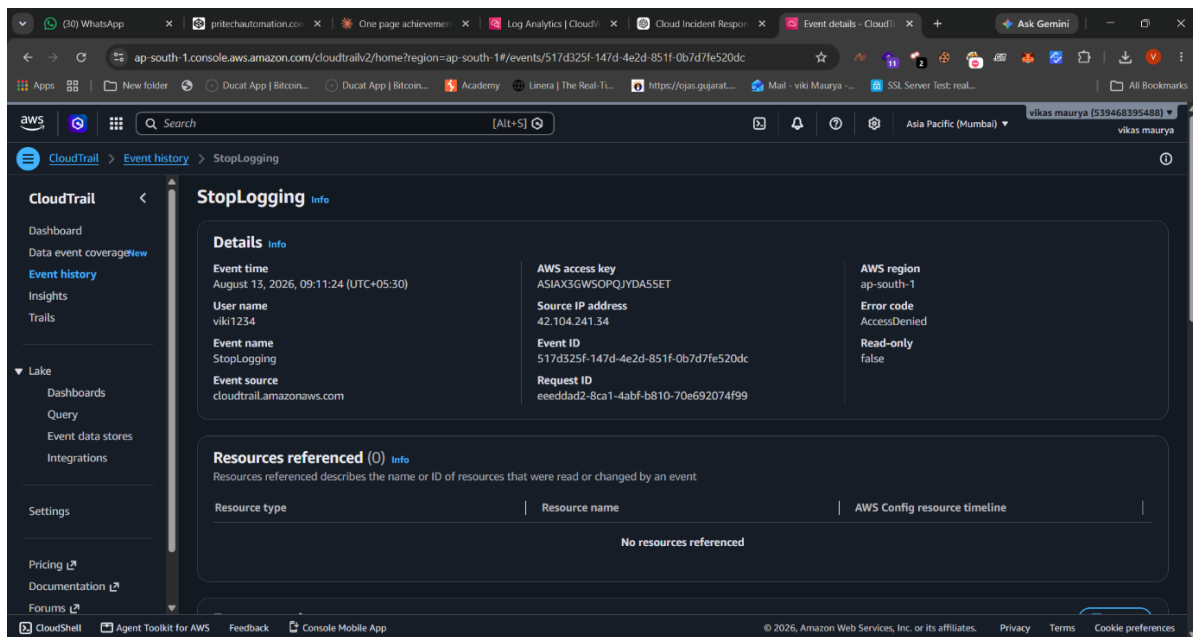


Figure 44. Logging integrity issue highlighted by the project evidence

The screenshot supports the lesson that security controls need monitoring of their own configuration. An attacker who first checks the logging setup and then attempts to change it is showing awareness of defensive controls.

15. Conclusion

This AWS cloud compromise simulation shows how several small security weaknesses can combine into a serious incident. The investigation began with IAM user creation, moved to privilege escalation and reconnaissance, reached sensitive S3 data and then attempted to reduce visibility by changing CloudTrail.

The investigation also demonstrates why timeline reconstruction matters. A single event can be difficult to interpret. The same event becomes much more meaningful when it appears next to another identity change, a resource discovery action or a logging change.

The final recommendation is to treat IAM, logging and data protection as connected controls. MFA, least privilege, protected CloudTrail, S3 access controls and automated alerts can reduce both the chance of compromise and the time needed to detect it.

Recommended Response Flow



A practical response sequence for a similar cloud incident.

Figure 45. Recommended incident response sequence